



How to Build an Effective Cyber Threat Intelligence Program

Introductions



JOHN DOYLE



STEVE SAVOLDELLI



MICHAEL DEBOLT

Workshop Goals

- Provide a CTI program build strategy
- Introduce CTI maturity assessments and how to use them
- Foster program improvements through exercises, self-reflection, and forced peer collaboration
- Make you want to re-watch '90s/'00s cartoons, anime, and movies

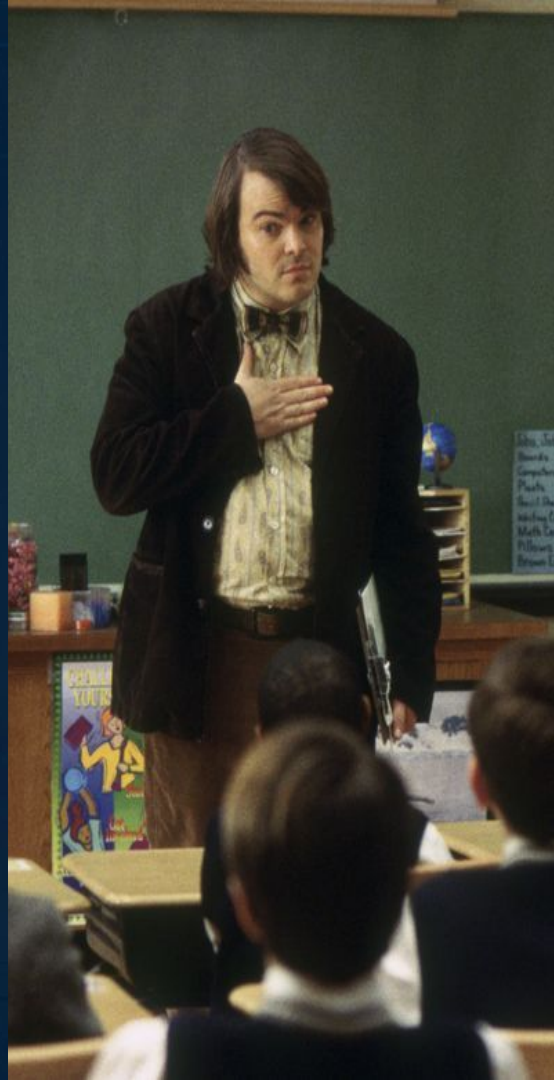
Agenda

- Designing for Success
 - Design
 - Build
 - Operate
 - Enhance
- Survey of Existing CTI Maturity Frameworks
- [Debo's section]

- There is a workshop workbook we will use:

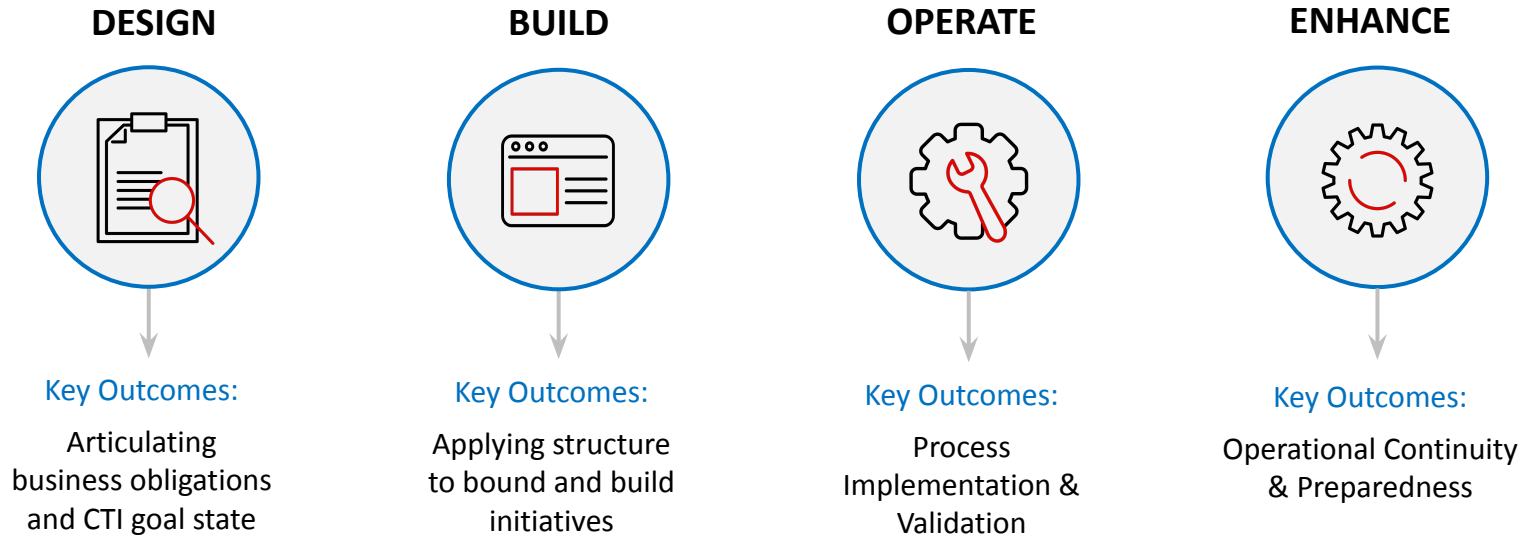
- It will contain links to CTI program build resources (templates, how to guides, and for our in-class exercises)

- We will be doing 10 minute breakout sessions with your neighbors



Programmatically Building a CTI Function

We will use a multi-phase, sequential approach in building a program:





Designing for Success

Design

Let's get dangerous!



Which of the following is the most important to have when establishing a CTI Program?

- A. Capable Analysts
- B. Processes
- C. Leadership Buy In
- D. A Threat Intelligence Platform (TIP)

Which of the following is the most important to have when establishing a CTI Program?

- A. Capable Analysts
- B. Processes
- C. Leadership Buy In**
- D. A Threat Intelligence Platform (TIP)



Why Should You Exist?

Thanks, Sierra and Rachel for teeing this up for us!



DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state

Why Should You Exist?

Creating a CTI program, like any other program, begins by defining:



Mission: the purpose of your intel program



Vision: what an ideal program looks like



Goals: how you'll achieve that ideal program



Values: the culture you'll form within the program

DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state

Considerations During the Process

- How does this improve current state or drive efficiencies?
- Think in terms of return on investment for the organization.



Mission



Vision

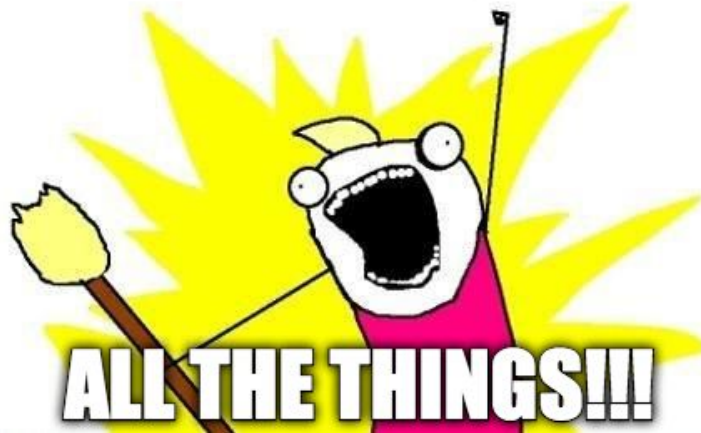


Goals



Values

ALIGN



DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state

Having Trouble Thinking of a Mission/Vision?



CTI provides timely and relevant insights about the cyber threat landscape, cyber threat actors, their capabilities, and motivations to inform risk exposure, planning, and cyber defense actions.

DESIGN



Key Outcomes:

Articulating business obligations and CTI goal state

Program Charter

- Codifies mission, vision, and goals
- Provides authority to operate

Mandatory

- Program Title
- Program Owner
- Senior Sponsor
- Authorization to Operate
- Sign off/Plan Establishment Date
- Program Description
- Program Objectives
- Justification
- Goals
- Review Frequency
- Change Log

Optional

- Program Milestones
- Critical Success Factors
- Assumptions and Constraints
- Estimated Costs
- People Requirements
- Tool Requirements



DESIGN



Key Outcomes:

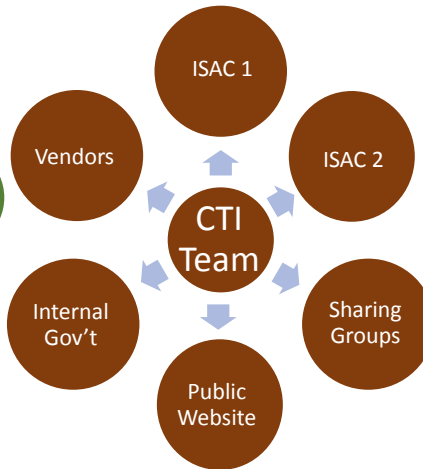
Articulating
business
obligations and CTI
goal state

Socialize Forthcoming CTI Program, Identify Initial Stakeholders

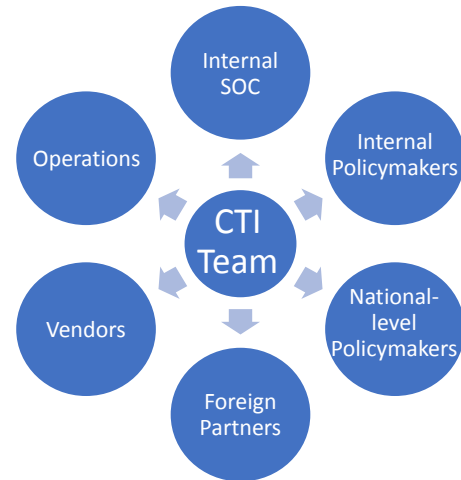
Private Sector - In-House



Government - CERTs



Government - Mil/Intel



DESIGN



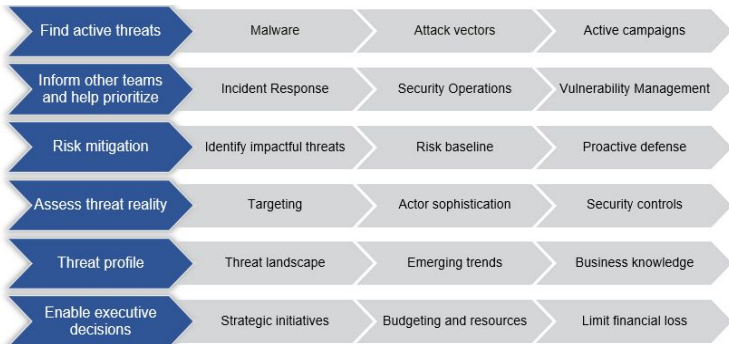
Key Outcomes:

Articulating
business
obligations and CTI
goal state

Establish Realistic Goals and Milestones

- Goals and Milestones:
 - Consider stakeholders/customers
 - Identify suspected intelligence needs
 - Vet/validate during other phases

Common CTI Use Cases:



Audience Type:	Tactical Level	Operational Level	Strategic Level
Customer Roles:	- Security Operations Center - Network Operations Center	- Incident Response Team - Vulnerability Management Team - Forensics Team - Red Team/Pen Testing	- Chief Information Security - Security Management - Risk Analysts
Customer Tasks:	- Indicators to security tools - Monitor, escalate alerts (triage)	- Determine attack vectors - Patch systems - Remediate - Hunt for breaches	- Allocate resources - Communicate with executives
Problems They Face:	- False positives - Alert overload	- Event reconstruction tedious - Difficult to identify damage - Difficult to prioritize patches	- No clear investment priorities - Executives are not technical
Value-add From CTI:	- Validate and prioritize indicators - Prioritize alerts	- Add context to reconstruction - Prioritize patches - Focus in on potential targets	- Demystify threats - Prioritize based on business risk

DESIGN

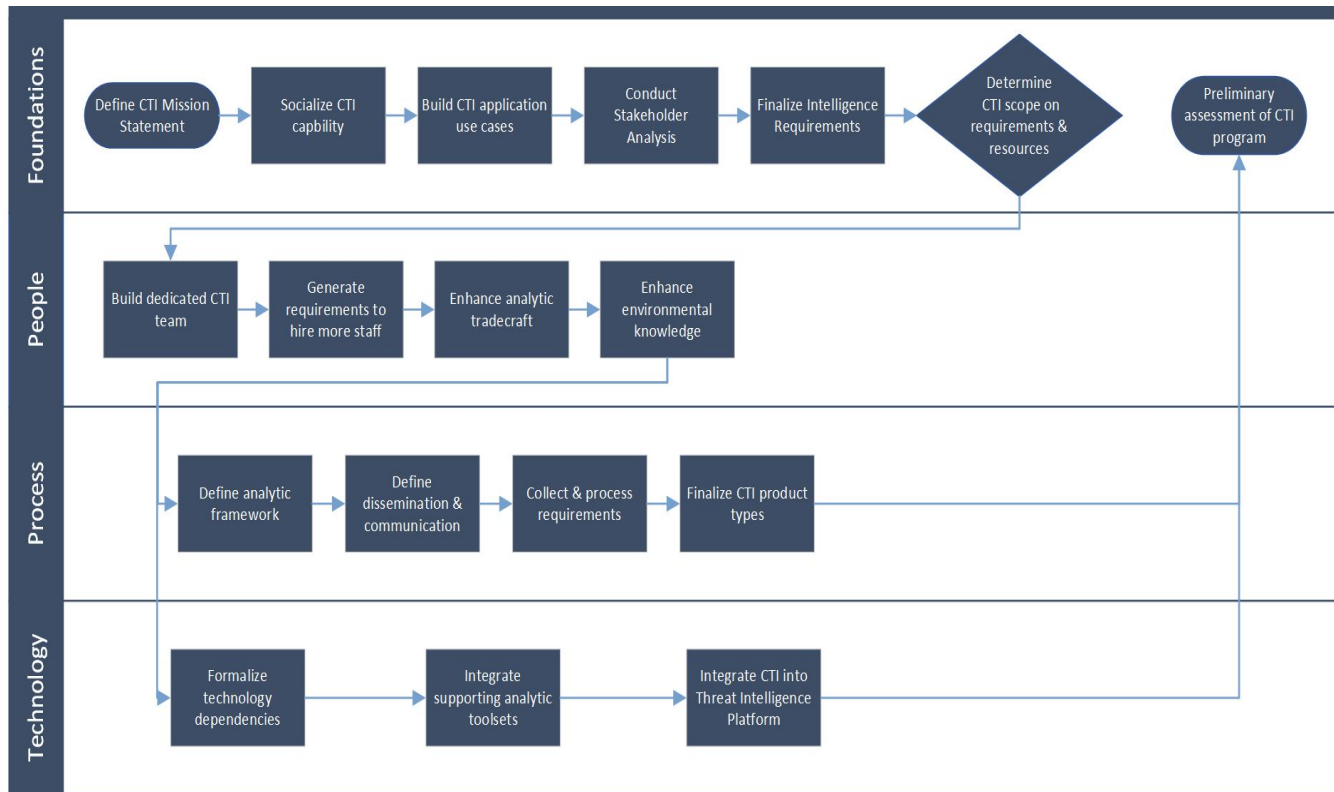


Key Outcomes:

Articulating business obligations and CTI goal state

Translate Them to a Conceptual Roadmap

Ideally, broken out over quarters, projected out 12-18 months



DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state

10 minute Group Discussion

Topic: Budget and Planning Process

Questions to help drive discussion:

- Is your team aware/leadership transparent about the team budget and its planning process?
- How do you go about translating needs into budget conversations?
- How do you track and convey opportunities for program investment?
- What are the major challenges you face when it comes to budget and planning processes?

Resource Planning

- Create a rough estimate of costs to run the CTI team
 - Shared budgets may exist for items like tools, data sets, licenses; training; travel; or awards.
 - A bulk of the team budget is allocated towards personnel.
- Staff slots are sometimes mandated at higher levels and organizational needs may mandate headcount to meet demands.
 - Contracting for staff augmentation can fill a staffing shortage for which there is no available billets.
 - There are pros and cons associated with contract staff augmentation. Based on attrition, the contractors may become the institutional knowledge.
- The team will likely require some additional software and access to data sets to answer intelligence requirements.

Levels of Effort	Objective(s)	Metric	Target Value
Financial Requirements	Technology Costs:		
	1. RFI ticketing system		
	2. Centralized system for storing and communicating intelligence products	Annual	<\$25,000
	3. Collection management tracking and evaluation system		
	Third Party Intelligence:		
	1. Commercial Intelligence subscription		
	2. Enrichment data services and licensing (pDNS, Shodan)	Annual	<\$450,000
	3. Staff augmentation		
	Analyst Tools:		
	1. Communication		
	2. Collaboration		
	3. Data visualization software	Annual	<\$50,000
	4. Graphics development software		
	5. Virtual Machine and Operating System licenses		

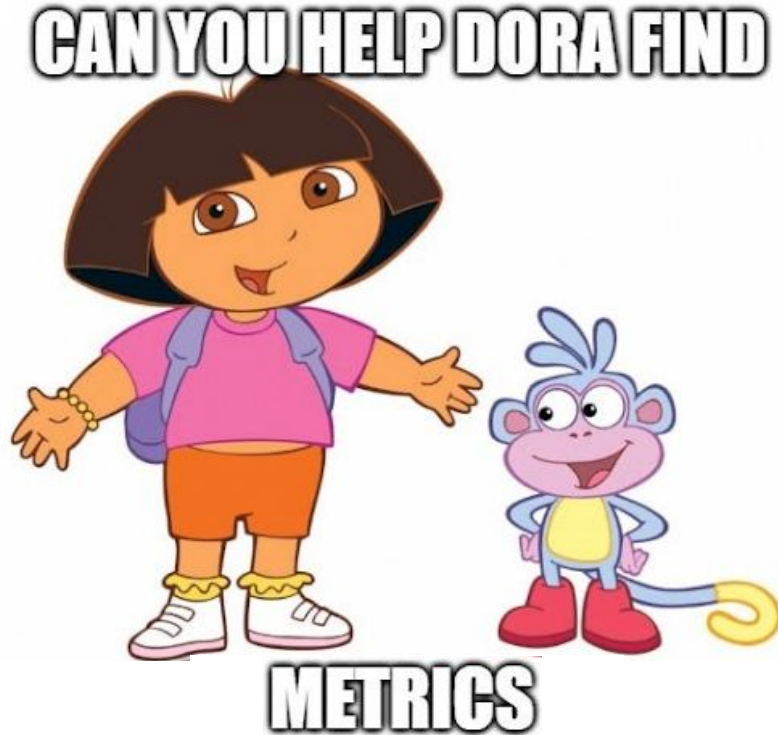
DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state

Metrics



Lo siento, Dora, las personas son malas con las metricas!

DESIGN



Key Outcomes:

Articulating
business
obligations and CTI
goal state



Build

Let's Take Stock and Decide What's Next

Done in Design

- ✓ Mission, Vision, Goals, Values
- ✓ Program Charter
- ✓ Initial Socialization/Stakeholder
- ✓ Use Case Identification
- ✓ Forecast Budget Asks
- ✓ Develop Preliminary Metrics
- ✓ Devise Milestones
- ✓ Build Roadmap

Done in Build



BUILD



Key Outcomes:

Applying structure
to bound and build
initiatives

10 minute Group Discussion

Topic: Prioritizing what to build first

Items to help drive discussion:

- Stakeholder Analysis and Use Case Identification
- Intelligence Requirements Generation
- Ideal Team Composition and Structure
- Creating Open Job Reqs
- Developing a CTI Program Wiki and Team Style Guide

Stakeholder Analysis Re-visited

- Embrace your role as an **educator**
 - Identify intelligence use cases
 - Explain CTI; explicitly call out that it is a customer service function
- Don't assume **prior knowledge**, you adapt to their frame of reference
 - Use plain English i.e. don't use the words "intelligence requirements"
 - Ask about existing workflows, outcomes, and metrics they use
 - Identify how they message up success and challenges
- Start **simple**, embrace **agility**
 - Discuss notional support, timelines, and preferred output formats
- Document everything

Intelligence Stakeholder Interview

Use this form to interview intelligence stakeholders and develop their intelligence and production requirements. This form can be either sent to the stakeholder for completion on their own or completed by the CTI manager. Regardless of who completes this, it MUST be agreed upon by both the CTI manager and the stakeholder before it can be finalized.

SECTION 1: INTELLIGENCE STAKEHOLDER INFORMATION

Record essential stakeholder information here:

1. Stakeholder team name – PIR code
2. Primary point of contact (name - email)
3. Functional area(s) of responsibility
check all that apply:
 - ☐ Security Operations (SOC)
 - ☐ Incident Response (IR)
 - ☐ Senior Management / Executives
 - ☐ Fraud
 - ☐ Vulnerability Management
 - ☐ Risk Management
 - ☐ Insider Threat
 - ☐ Data Loss Prevention/Pre
 - ☐ Line of Business
 - ☐ Other:

SECTION 2: INTELLIGENCE SUPPORT

Record the use-cases requiring intelligence support and deliverables. Ask your stakeholder the following questions:

4. Generally, what intelligence information do you need to do your job?
What keeps you up at night?
5. What is your success criteria? How will you be satisfied with the intelligence support we provide you?
6. What use cases do you need intelligence support for?
check all that apply:
 - ☐ Network and endpoint protection
 - ☐ Penetration testing and attack emulation
 - ☐ Vulnerability and patch management
 - ☐ Insider threat
 - ☐ Threat hunting
 - ☐ Risk and compliance
 - ☐ Fraud
 - ☐ Identity management
 - ☐ Other:
7. What type of product/service do you prefer for intelligence support?
check all that apply:
 - ☐ Formal Report
 - ☐ Regular Briefing
 - ☐ IOC feed data
 - ☐ On demand requests for information (RFI)
 - ☐ Other:

BUILD



Key Outcomes:

Applying structure
to bound and build
initiatives

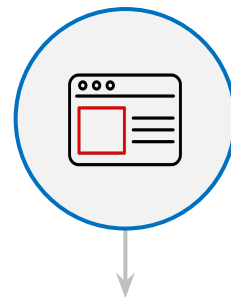
Gather Intelligence Requirements

- Capture general use cases, specifics, intelligence driven outcomes
- Store centrally, add prioritization, status, and stakeholder POCs
- Look for overlap and efficiencies

Intelligence Requirement			
PRIORITY:	1 / HIGH - Less than X days	2 / MED - Less than X days	3 / LOW - Less than X days
CATEGORY:	Adversary TTPs	Threat Actor Tracking	Service Availability
FOCUS:	CTI analysts will leverage external sources to perform tactical and trend analysis regarding new malware development or evolution (weaponization). Analytic focus will be on identification of TTPs and curation of high value indicators of compromise.		
EXPECTED OUTCOME:	Resulting product output will be used to guide Cyber Security Operations' monitoring, detection, and response functions.		

Requirement	Status	Priority Level	Last Updated	Primary Stakeholder(s)	Reporting Intent	Intel Product Output(s)
The CTI Team will monitor for cyber threat groups attempting to compromise <organization> or its industry peers	Active	1	June 2022	Risk Management Senior Leadership CIRT	Situational Awareness	Monthly Threat Report
The CTI Team will capture Tactics, Techniques, and Procedures (TTPs) for groups targeting industry peers	Active	1	June 2022	CIRT SOC Purple Team	Situational Awareness Hunting	Adversary Playbook Threat Hunting Guide
The CTI Team will prioritize cyber threat groups and trends based on understanding critical business systems, individuals, and client data	Active	2	June 2022	Risk Management Senior Leadership	Risk Impact Assessments	Annual Cyber Threat Trends Report
The CTI team will monitor for newly discovered vulnerabilities and adversary groups exploiting them	Inactive	3	Jan 2022	Vulnerability Management	Situational awareness Patch Prioritization	Vulnerability Dashboard

BUILD



Key Outcomes:

Applying structure to bound and build initiatives

Communicating up plays an important role in ensuring CTI program traction. What's the most important reason?

- A. Escalation Resolution
- B. Recurring Updates on Program Growth Status
- C. Provides CTI a Seat at the Table and Perspective into Leadership's Thoughts
- D. Builds Leadership Trust and Confidence

Communicating up plays an important role in ensuring CTI program traction. What's the most important reason?

- A. Escalation Resolution**
- B. Recurring Updates on Program Growth Status**
- C. Provides CTI a Seat at the Table and Perspective into Leadership's Thoughts**
- D. Builds Leadership Trust and Confidence**



Comms Plan and Escalation Pathways

- Regularly scheduled check in sessions with leadership on the status of the CTI program can have multiple benefits:
 - They feel invested in the program and become a better advocate/champion
 - Offers perspective in leadership's thoughts on broader strategy
 - Provides CTI a seat at the table to influence security strategy decisions
 - Builds trust and confidence in the team and CTI management
 - Also serves as an out-of-band escalation pathway



BUILD

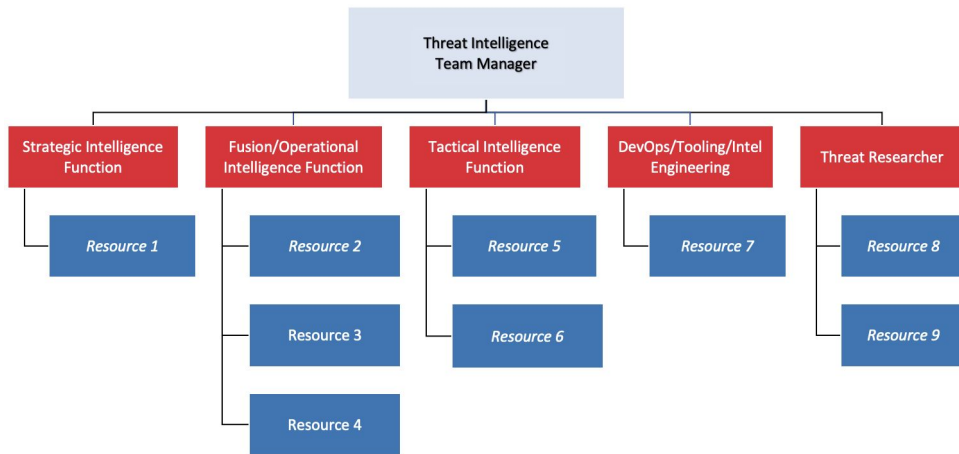


Key Outcomes:

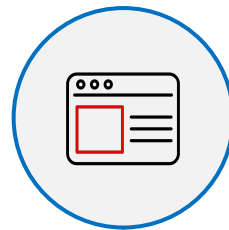
Applying structure
to bound and build
initiatives

Scaling Up: Envisioning the CTI Team Structure

- Intelligence requirements will fuel hiring decisions
 - Envision a rough team role and responsibilities break out
 - Staff composition with various skills, experience, and abilities will in some ways dictate team structure, job roles, and individual responsibilities
 - Human Resources, internal processes, and politics can affect time it takes to get a candidate through the pipeline from initial discussions to on-boarding
 - Budget constraints, the organization's reputation, and market demand will dictate ability to recruit talent.



BUILD



Key Outcomes:

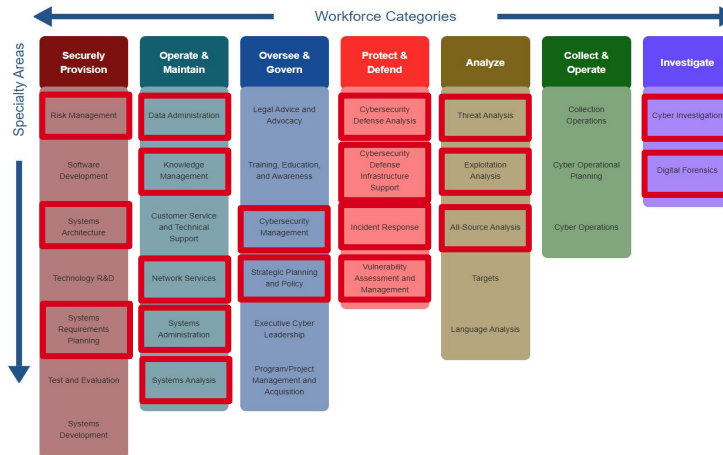
Applying structure
to bound and build
initiatives

Hiring the Right Fit

Requirements levied on CTI has grown over the past decade requiring breadth and depth in knowledge, skills, experience, and abilities

- Problem: NIST 800-181 (the National Initiatives for Cybersecurity Education (NICE)) framework does not contain a fulsome CTI analyst job classification
- Solution: In May 2022, Mandiant released the [CTI Analyst Core Competencies Framework](#)
- 3 goals outlined for it:
 - Identify areas for team or individual growth, determine development roadmaps, align training opportunities to ensure CTI skills progression
 - Provide a guidepost for aspirant CTI analysts to tailor their studies
 - Help non-intel personnel understand roles and responsibilities of a CTI analyst, improve collaboration

	Analyze Performs highly-specialized review and evaluation of incoming cybersecurity information to determine its usefulness for intelligence.	Specialty Area ▾
	Collect and Operate Provides specialized denial and deception operations and collection of cybersecurity information that may be used to develop intelligence.	Specialty Area ▾
	Investigate Investigates cybersecurity events or crimes related to information technology (IT) systems, networks, and digital evidence.	Specialty Area ▾
	Operate and Maintain Provides the support, administration, and maintenance necessary to ensure effective and efficient information technology (IT) system performance and security.	Specialty Area ▾
	Oversee and Govern Provides leadership, management, direction, or development and advocacy so the organization may effectively conduct cybersecurity work.	Specialty Area ▾
	Protect and Defend Identifies, analyzes, and mitigates threats to internal information technology (IT) systems and/or networks.	Specialty Area ▾
	Securely Provision Conceptualizes, designs, procures, and/or builds secure information technology (IT) systems, with responsibility for aspects of system and/or network development.	Specialty Area ▾



BUILD



Key Outcomes:

Applying structure to bound and build initiatives

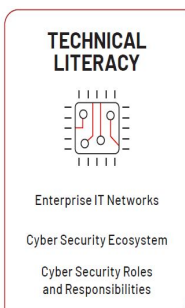
PROBLEM SOLVING

Critical Thinking

Research and Analysis

Investigative Mindset

- A graphic titled "PROFESSIONAL EFFECTIVENESS" in bold black capital letters. Below the title is a target icon with three concentric circles and a red arrow hitting the center. Underneath the target, the following skills are listed in black text: "Communication", "Teamwork and Emotional Intelligence", and "Business Acumen".



Applying structure to bound and build initiatives

[illegible]

Hiring the Right Fit

- Examples of practical CTI interview questions available in [this blog](#):

Breaking Into the CTI Field: Demystifying the Interview Process and Practice Interview Questions



Shinigami · Follow
12 min read · Sep 5, 2022



Hello friends. Following on the SANS webcast I hosted the other day, ["Intelligently Developing a Cyber Threat Analyst Workforce"](#) and coming on the backdrop of reading Katie Nickel's excellent blog post on how [Red Canary recruits CTI talent](#), I decided to write a blog post focused on assisting aspirant CTI analysts on how to break into the field and prepare for CTI job interviews. If you are interested in determine what pay bands look like for CTI roles, I suggest you read Rob Lee's blog ["What to Expect When Interviewing at Dragos: Lessons Learned for You and Other Employers"](#). Similarly, if you are interested in what can be expected of you working in one of these roles, I have highlighted what we look for at Mandiant in this blog post, ["Introducing the Mandiant Cyber Threat Intelligence \(CTI\) Analyst Core Competencies Framework Blog"](#). Katie touches on this in section 2 of the Red Canary blog.

Hat tip to @threathuntergrl and @Lawsecnet for feedback and peer review on this blog prior to publishing it.

Generic Interview Questions:

- Can you tell me about yourself, experience you have in the field, and any particular subject matter expertise you have in CTI?
- What would you self-assess to be your greatest strength(s) and how would that align with the organization's vision and team's mission based on our conversation?
- What makes you interested in this role working at <organization>?
- In your opinion, what is the role of CTI and how can it help organizations? Can you explain to me why organizations should consider investing in developing a cyber threat intelligence capability and instances where it might not be appropriate for them?
- When we think about CTI, we often bucket analysis into support at the strategic, operational, or tactical level. Based on this grouping, which do you often find yourself often supporting and can you provide us with examples? How comfortable would you be supporting one of the other forms of intelligence analysis categories?
- Can you explain some of the motivations behind cyber operations and how we assess what they are?
- Can you tell us about a recent cyber security vendor report or cyber security related news article you read. What was the primary message they were attempting to convey, its significance, and at least one interesting tidbit you found in it?
- What are some industry trends you have observed forming over the past 12 months?
- Can you name a CTI framework you are familiar with, explain what it is, why it was created, what problem it allowed the CTI community to overcome, and how you could or have applied it in your existing workflow?

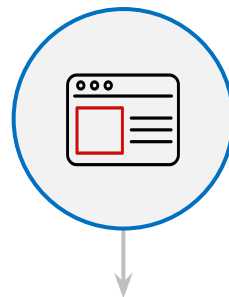
Understanding IT concepts, Threat Concepts, CTI research, and Cyber Security Controls and Processes:

- Can you describe the properties of a public IP address – irrespective of IPv4 or IPv6, how it is provisioned, and any limitations we should consider when attempting to correlate it to previous adversary infrastructure or when taking defensive actions?
- What is an appropriate security action to take internally if we detect malware is communicating with a public AWS IP address?
- What is the significance of the NTDS.dit file? If an adversary was able to steal it, what could they do with the data stored in it and what security action would that require the organization take?
- Can you explain the patching process, how it works in enterprise environment, and how this relates to risk exposure and cyber risk?
- Living off the land (LOTL/LOLBINS/LOLBAS) is a trend that the cyber security industry is observing malicious cyber actors use with increased frequency. Please explain to us what living off the land operations entail, an example of such living off the land capability, and an example of an actor group and how they use living off the land techniques.

Research, Analytic Tradecraft, and Problem Solving:

- Please explain why different vendors use different names for what appears to be the same intrusion sets and how you have used these different names in your previous or current job role.
- Being able to discern the quality of data sources is an important function of a CTI analyst. To that end, how do you judge the credibility of different vendor's reporting when crafting finished intelligence?
- Can you define the types of indicators of compromise (IOCs) that exist, walk me through strengths and limitations for each, and describe how you could enrich and pivot against the various types. Name the tools or data sets you would use during the enrichment/pivoting process.
- What is your workflow when you come across a suspicious IOC?
- When creating a piece of finished intelligence, how do you decide what to write about? What data sets did you evaluate, how did you enrich the data to bring to light the broader context, and what tools did you use to support this effort?
- The team has determined that an adversary group we are tracking is using the same 10 permutations within its URI naming convention. What would you do to write a simple signature to detect whether we have seen any of our other systems within the environment communicating with them? Likewise, how would you write a signature to detect additional URI naming conventions that have been observed by use likely by this malicious actor?

BUILD



Key Outcomes:

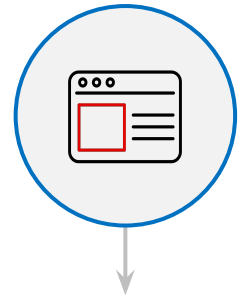
Applying structure to bound and build initiatives

Team Skills Matrix/Baselines

- Captures strengths and growth opportunities across the team
- Helps identify single points of failure to prioritize training needs
- Should be used in tandem with a minimum skills baseline and recommended training roadmap
- Team member self-ratings may help assuage potential hurt feelings for areas identified as weaker

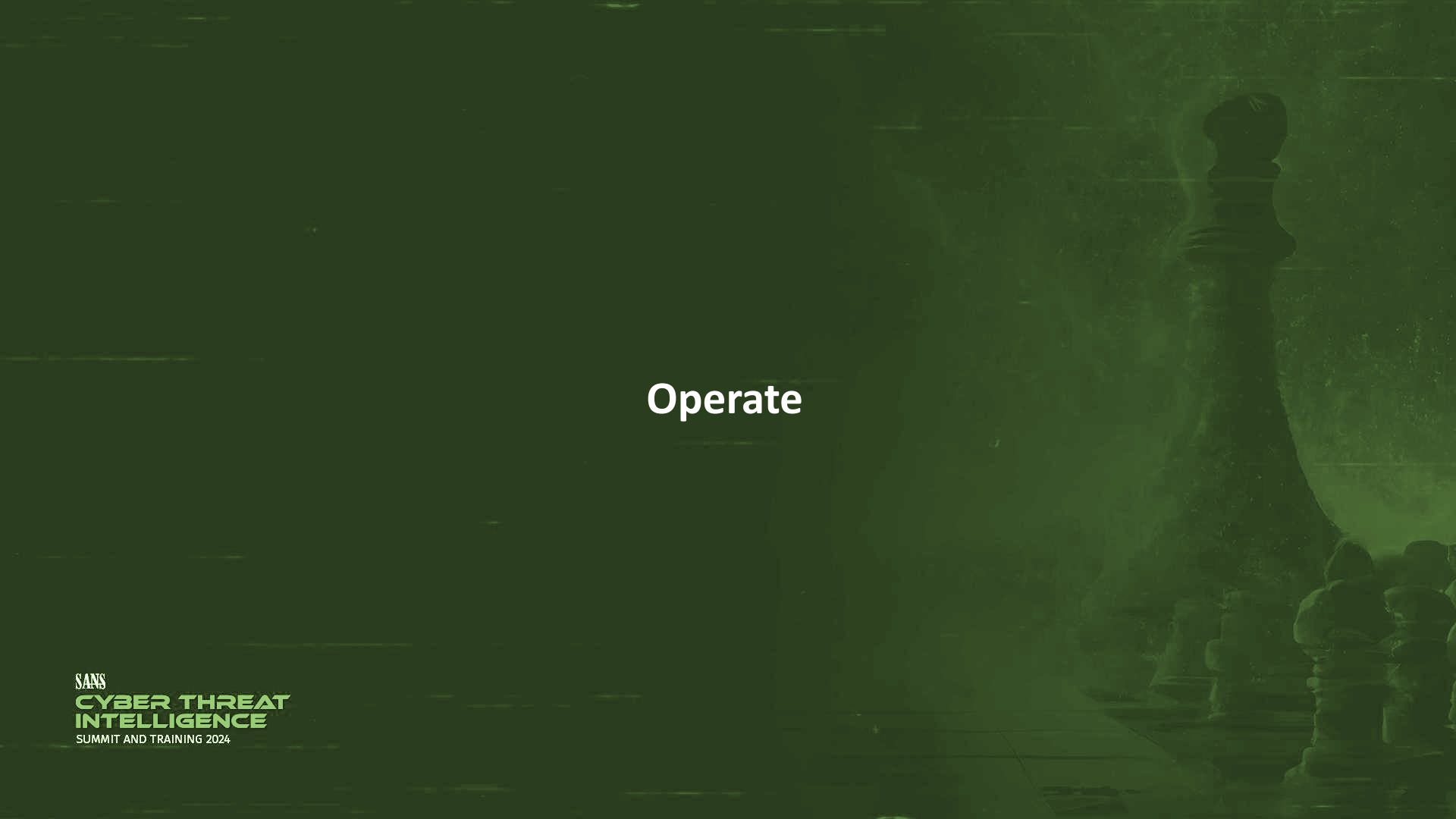
Team Member	Writing	Presenting	Relationship Management	Intrusion Analysis	Adversary Tradecraft	DevOps
John	Expert	Expert	Beginner	Advanced	Advanced	Intermediate
Jim	Intermediate	Intermediate	Beginner	Advanced	Advanced	Expert
Bob	Intermediate	Expert	Beginner	Expert	Expert	Beginner
Sally	Expert	Advanced	Expert	Beginner	Beginner	Beginner
Anna	Beginner	Beginner	Advanced	Beginner	Beginner	Beginner
Mike	Advanced	Intermediate	Expert	Intermediate	Intermediate	Beginner

BUILD



Key Outcomes:

Applying structure
to bound and build
initiatives



Operate

Seriously, there's more? Can't someone just do this for me?

Have you met John, Steve, and Debo?



Let's Take Stock and Decide What's Next

Done in Design

- ✓ Mission, Vision, Goals, Values
- ✓ Program Charter
- ✓ Initial Socialization/Stakeholder
- ✓ Use Case Identification
- ✓ Forecast Budget Asks
- ✓ Develop Preliminary Metrics
- ✓ Devise Milestones
- ✓ Build Roadmap

Done in Build

- ✓ Stakeholders
- ✓ Use Cases and Intelligence Requirements
- ✓ Communications Paths
- ✓ Escalation Criteria
- ✓ Notional Team Structure
- ✓ Job Roles and Responsibilities
- ✓ Open Reqs

Done in Operate



OPERATE



Key Outcomes:

Process
Implementation &
Validation

A graphic with a red and blue background, featuring the text "DAILY DOUBLE" in large, white, bold letters. Below the text, there are stylized, glowing lines that resemble a book or a set of papers.

DAILY DOUBLE

15 minute Group Discussion

A graphic with a red and blue background, featuring the text "DAILY DOUBLE" in large, white, bold letters. Below the text, there are stylized, glowing lines that resemble a book or a set of papers.

DAILY DOUBLE

Topic: Stakeholder Support

Fill out the “Intelligence Services and Use Cases” section in the Intelligence Capability Assessment then discuss the following:

- How does your organization approach stakeholders?
- How does it handle if a stakeholder provides feedback that the support is lacking and not meeting the mark?
- How does this change if this becomes regular feedback from the same stakeholder(s)?

Knowledge Management and Team SOPs

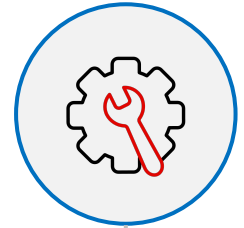
- Products delivered via e-mail benefit from a parallel storage system, at least accessible to CTI.
- Building on your old products is critical for a strategic and trend-based workstream, plus it helps in the identification of unmet consumer demand.
- Program components that support regulatory compliance benefit from transparency.

- ▼ Cyber Threat Intelligence
 - ▼ Foundations and Structure
 - Governance and Policy
 - ▼ Onboarding and Training Procedures
 - Access
 - Meetings
 - HR and Corporate Services
 - Corporate Collaboration Tools



Name ▼	Notes ▼	Modified ▼
Onboarding Documents and Master SOPs		May 22, 2022
Charter, Mission, Vision		May 22, 2022
CTI Discipline Training Primers and Guides		May 22, 2022
Team Bios, Contact Info, Call Tree Card		May 22, 2022
Analytic Standards and Practices		May 22, 2022
Wiki Content		October 9, 2023
FINTEL		May 22, 2022
Collection Plan, Stakeholder Intel Reqs		May 22, 2022

OPERATE



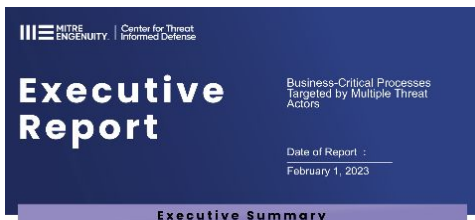
Key Outcomes:

Process
Implementation &
Validation

Standardizing Practices and Procedures

Standardization for:

- Workflows for research, triage, storage, tagging schema, etc.
- Document review periods
- Analytic product catalog and templates
- Style Guide
- Conveying estimative language/uncertainty
- CTI frameworks used, when, and how



OneNote is increasingly being leveraged to distribute malware by cyber criminals. The reliance on sharing data via OneNote in the company to encourage collaboration makes our users susceptible to this new initial intrusion vector and threat actors are leveraging legitimate Microsoft services to send OneNote files that contain malware. Unlike traditional forms of phishing, training is unlikely to be an effective mitigation as business process involves the expectation of OneNote links to be sent via email.

Key Points
- Over the last four months there has been a large increase in the use of Microsoft OneNote documents to successfully deliver malware. - This increase is likely attributed to Microsoft blocking macros by default in Microsoft Office applications in 2022 due to long-term abuse by threat actors. - Employee awareness training is unlikely to substantially reduce our vulnerability to this new method of exploitation because users are conditioned to click OneNote links sent to them via Microsoft addresses.

ASSESSMENT
We now face increased risk because cyber threat actors are targeting Microsoft OneNote, which is critical to our regular business operations. OneNote abuse poses a larger risk than malicious Word or Excel documents did prior to the macro change because we did not rely on macros for business processes. The new technique is effective in bypassing detection, introducing gaps in our threat detection coverage.

CTID 754-2023
Executive Report

TLP: CLEAR
02/01/2023

Criticality: Critical
Page 1

OPERATE



Key Outcomes:

Process
Implementation &
Validation

Collection Management Framework

- Captures tools and data sets used, broken out in a logical manner that...
- Either describes the utility/fields, price point, licensing information or...
- Maps to how it will be used to address intelligence requirements and CTI use cases

Sample Collection Plan

Effective Date:
Next review:

Paste top 20 Collection Guidance list from PIR Register to here

Select IRs from the CU-GIRs, or develop your own based on your stakeholder's needs. These are the questions you need to answer in your intelligence deliverables to your stakeholders.

Collection Guidance			Score	Priority Intelligence Requirements (PIRs)	Social media	News or security media	Indicator feeds	Dark web	Underground forums	Marketplaces	Cryptomails	Dump blogs	Penetration network	Internal network	Insider threats	Email	Data store	Tactical	Operational	Strategic	Formal report	Regular briefing	Ad hoc briefing	Immediate or on-demand	Day	Weekly	Monthly	Quarterly	Other		
1	5.5.3 - Information or data breach	177	Determine capability and intent of adversaries compromising or disclosing information belonging to or impacting us.																												
2	6.1.3.1 - Banking and securities industry	138	Determine capability and intent of adversaries targeting or attacking the financial services industry.																												
3	1.1.5 - Information-stealer malware	138	Identify new and emerging information stealer malware including capabilities, functionality and threat levels.																												
4	4.1.4 - Drop accounts and fund transfers	138	Identify capability, intent, and modus operandi of adversaries transacting illicit funds using drop accounts belong to our customers.																												
5	1.2.2 - Ransomware-as-a-Service (RaaS)	125	Identify capability, intent, and modus operandi of existing, new, and emerging RaaS operators and affiliates.																												
6	4.2.2 - Compromised credentials	125	Identify and characterize compromised credentials belonging to us.																												
7	5.5.4 - Blackmail	111	Determine existing, new, and emerging TTPs employed by adversaries to blackmail victims.																												
8	1.3 - Malware development, support and delivery	111	Determine capability and intent of adversaries involved the development, support, and distribution of malware targeting us or our industry.																												
9	4.2.1 - Payment card fraud	111	Identify and characterize compromised payment carding activity impacting us.																												
10	6.2.6 - North America	97	Determine existing, new, and emerging TTPs employed by adversaries targeting financial institutions in the United States.																												
11	1.3.5 - Malware crypting	97	Identify and characterize existing, new, and emerging malware crypting products, services, tools, or methodologies and their success rates.																												
12	4.2.5 - Compromised network or system access	97	Identify and characterize adversaries selling network accesses impacting us, our supply chain, or third parties.																												
13	6.2.4 - Europe	83	Determine existing, new, and emerging TTPs employed by adversaries targeting financial institutions in the Europe, specifically UK.																												
14	1.3.10 - Exploit kits	83	Identify and characterize existing, new, and emerging exploit kits.																												
15	4.1.2 - Money laundering	69	Identify and characterize existing, new, and emerging money laundering services, tools, or methodologies and their success rates.																												
16	1.1.1 - Ransomware malware	69	Identify new and emerging ransomware variants, capabilities, infection chains, and decryption methods.																												
17	4.1.9 - Business email compromise (BEC)	55	Identify and characterize adversary TTPs and tools used in BEC schemes.																												
18	3.1.1 - Bulletproof hosting (BPH) services	55	Determine widely used BPH services, downstream malicious activity they support, and detection methods.																												
19	4.4.2 - Spear-phishing	42	Identify and characterize existing, new, and emerging TTPs employed by adversaries for spearphishing.																												
20	1.3.8 - Malware spamming	42	Identify and characterize new and emerging malware spamming campaigns and targeting.																												
					12	11	7	12	14	19	10	9	4	14	15	10	11	10	7	15	16	10	14	10	18	16	7	0	15	16	0
					Coverage emphasis										Deliverable emphasis																

OPERATE

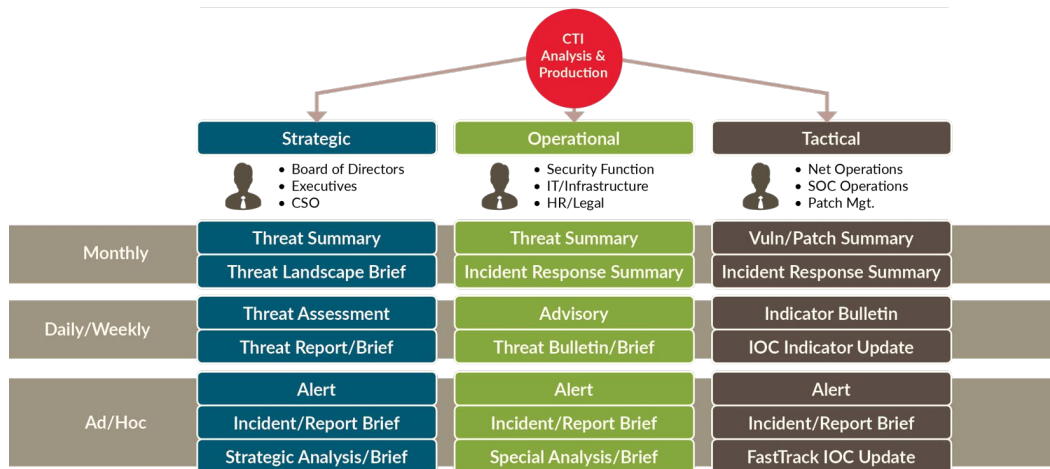
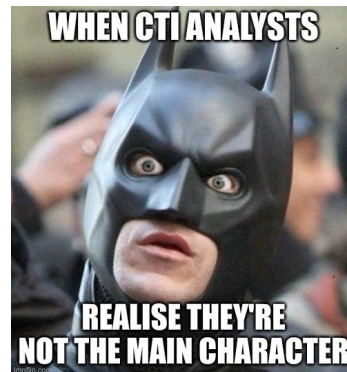


Key Outcomes:

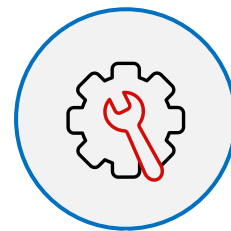
Process
Implementation &
Validation

Establishing a Product Catalog

- Details frequency, format, and modality for recurring intel products broken out by customer set
- Helps quickly orient newly onboarded analyst and stakeholders
- Pro-tip: maintain a pretty version for briefings and demos and an Excel version



OPERATE



Key Outcomes:

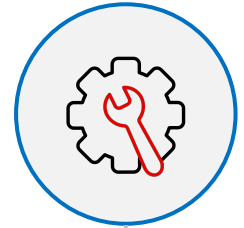
Process
Implementation &
Validation

Baselining Level of Effort

- Begin with the amount of overhead for an analyst. Vacation, We do not get 40 uninterrupted hours in a work week.
- Make an effort to estimate how long the team typically spends supporting a product or stakeholder.
- Certain project management or ticketing systems can generate these metrics automatically, but understand how that is generated and what it doesn't capture.
- The design is to establish baselines for the purpose of capacity planning. Use that to justify prioritization, resource needs, and as always, illustrate what you are not doing.

Analyst Hourly Assumptions	
Enter Time Away Variables	
Avg # of days of PTO an Analyst receives per year	20
Apprx # of overhead hours per Analyst per week	10
Annual Training (Internal) hours per Analyst	16
Annual Training (SANS courses, etc) hours per Analyst	40
Annual inefficiency estimate for all new and junior hires	0
<add new ANNUAL hourly variable>	
Enter Public Holidays per Year	8
General	
Hours per Week	40
Days per Week	5
Weeks per Year	52
Weeks per Quarter (Weeks per Year / 4)	13
Work Days per Quarter (Weeks per Qtr * 5)	65
Work Hours per Quarter (Work Days per Qtr * 8)	520
Calculated Variables	
Available Work Days (Days per Week * Weeks per Year) - Holidays	252
Overhead per Quarter (O/H Hrs per Week * Weeks per Qtr)	144
Holidays	
Holiday Hours per Year (Days Entered * 8)	64
Holiday Hours per Quarter (Holiday Hours per Year / 4)	16
Holiday Hours per Week (Holiday Hours per Qtr / 13)	1.2
Paid Time Off	
PTO Hours per Year (Weeks entered * 8)	160
PTO Hours per Quarter (PTO Hours per Year / 4)	40
PTO Hours per Week (PTO Hours per Qtr / 13)	3.1
Analyst Availability Adjusted for Holidays, PTO, and Overhead	
Quarterly	
Max available work hours	520
Available work hours sans PTO	480
Available work hours sans PTO and Holidays	464
Available work hours sans PTO, Holidays, and O/H	320
Weekly	
Max available work hours	40
Available work hours sans PTO	37
Available work hours sans PTO and Holidays	36
Available work hours sans PTO, Holidays, and O/H	26

OPERATE



Key Outcomes:

Process
Implementation &
Validation

Develop a RACI

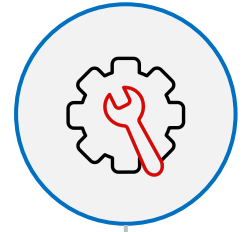
- Responsible, Accountable, Consulted, and Informed
- Or create a modified version, a RASCI, by adding “Supports” Responsible, Accountable, Consulted, and Informed
- Can be used internal to the CTI team to identify roles and responsibilities
- More broadly used to create a coordination list and identify “lanes in the road” or partnership areas between teams

Activity	Responsible	Accountable	Consulted	Informed
Identify and document cyber threat use cases	CTI	CTI	IT Leadership	Risk
Lead cyber risk assessments	Risk	Risk	CTI	IT Leadership
Develop threat models	IT Security	IT Security	Risk and CTI	IT Leadership
Validate cyber threats to crown jewel assets	CTI or red team	Risk	Risk	IT Leadership

	 FRODO	 SAM	 GANDALF	 ARAGORN	 ELROND
Decide on what to do with ring	C	I	A	C	R
Create Fellowship	R	C	A	C	R
Get the ring to Mount Doom	R	C	A	C	I
Distract and defeat enemies	I	R	C	R	I

Suzanna Haworth, Digital Project Manager (n.d.)

OPERATE

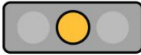
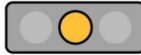


Key Outcomes:

Process
Implementation &
Validation

Partnerships and Data Classification

- Partnerships via ISACs, sharing communities of peers, or with national-level partners augment internal visibility
- Dissemination controls protect sensitive content from spillage to unauthorized users
 - This should map to or at least align with certain internal data loss prevention (DLP) software protection levels
- It establishes an agreement between the parties on how to use the shared data

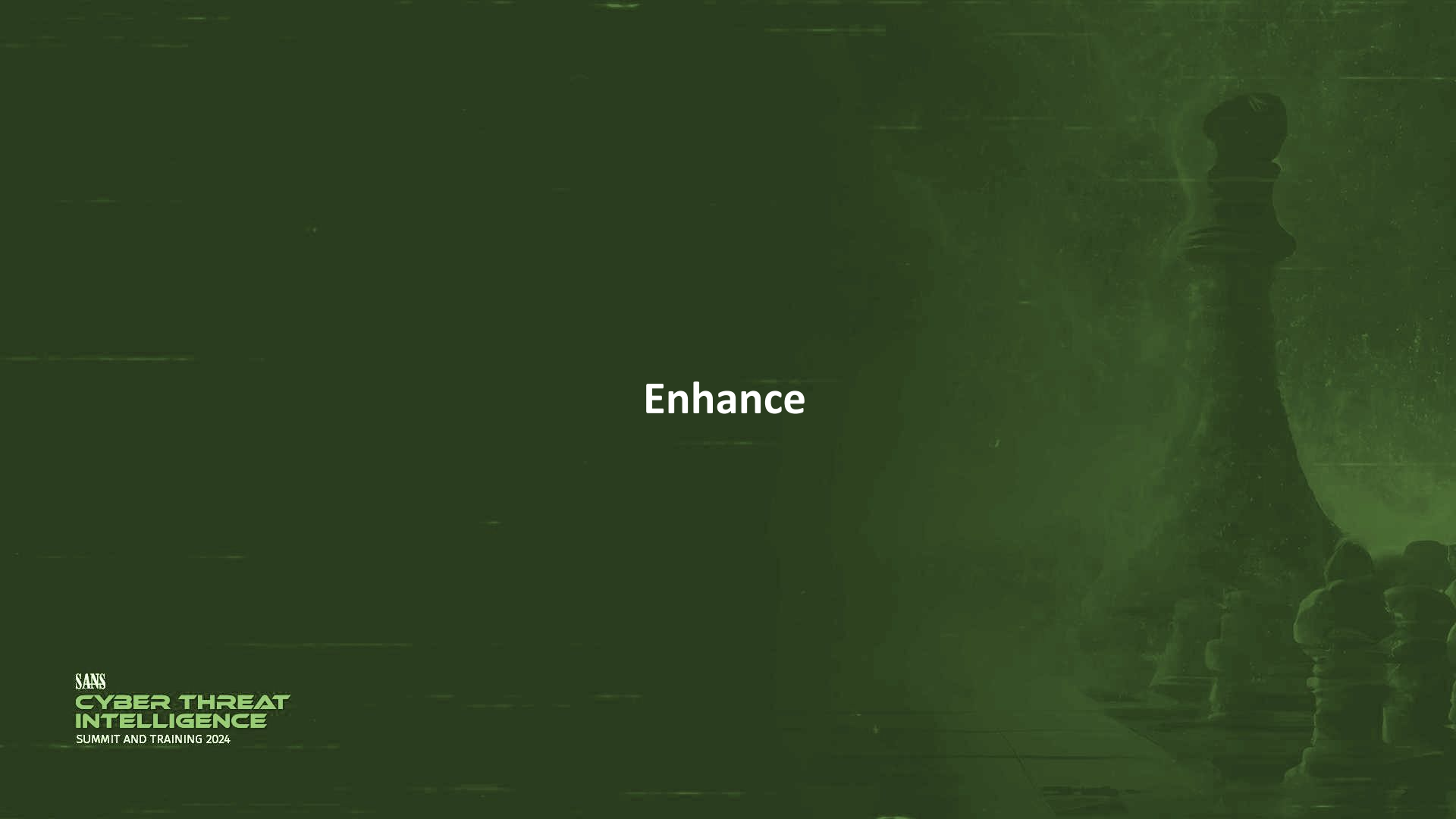
 TLP:RED	 TLP:AMBER	 TLP:AMBER+STRICT	 TLP:GREEN	 TLP:CLEAR
TLP: Red	TLP: Amber	TLP: Amber+Strict	TLP: Green	TLP: Clear
Not for disclosure, restricted to participants only.	Limited disclosure, restricted to participants' organization and its clients (see Terminology Definitions).	Limited disclosure, restricted to participants' organization.	Limited disclosure, restricted to the community.	Disclosure is not limited.

OPERATE



Key Outcomes:

Process
Implementation &
Validation



Enhance

Let's Take Stock and Decide What's Next

Done in Design

- ✓ Mission, Vision, Goals, Values
- ✓ Program Charter
- ✓ Initial Socialization/Stakeholder
- ✓ Use Case Identification
- ✓ Forecast Budget Asks
- ✓ Develop Preliminary Metrics
- ✓ Devise Milestones
- ✓ Build Roadmap

Done in Build

- ✓ Stakeholders
- ✓ Use Cases and Intelligence Requirements
- ✓ Communications Paths
- ✓ Escalation Criteria
- ✓ Notional Team Structure
- ✓ Job Roles and Responsibilities
- ✓ Open Reqs

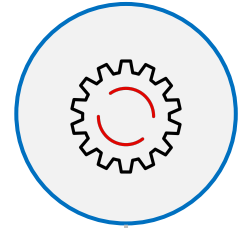
Done in Enhance

Tradeoff-aware optimization for resilience and marginal gains.

Done in Operate

- ✓ Standardizing Analytic Practices
- ✓ Establishing a RACI
- ✓ Building a Product Catalog
- ✓ Knowledge Management
- ✓ Team SOPs
- ✓ Collection Management Framework
- ✓ Partnerships
- ✓ Baselining Level of Effort

ENHANCE



Key Outcomes:

Operational Continuity
& Preparedness

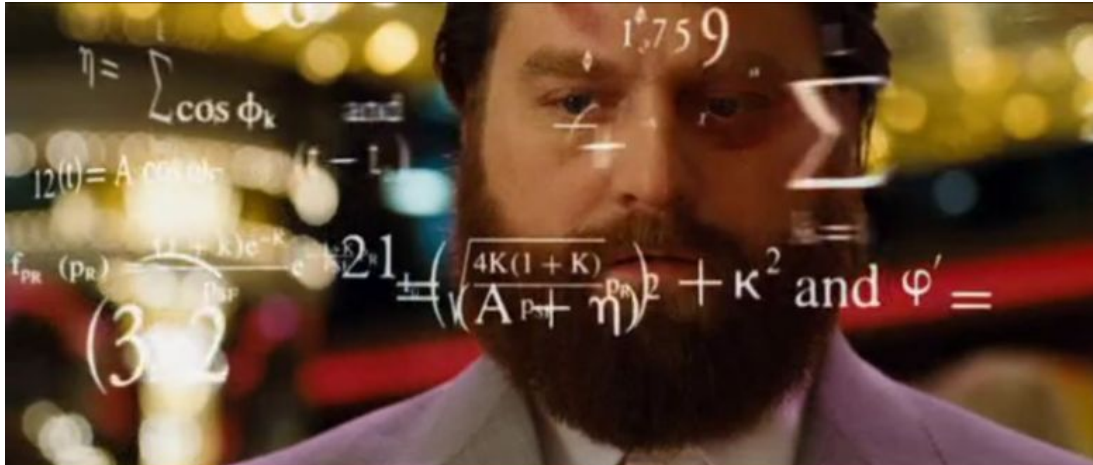
Metrics and the Quantification of Value

Internal Illumination

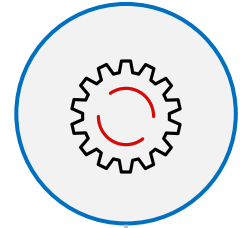
- Track efficiencies and gaps in production of knowledge-based output

Value-Capture

- Identify actions and outcomes supported by intelligence



ENHANCE



Key Outcomes:

Operational Continuity
& Preparedness

10 minute Group Discussion

Topic: Revisiting Metrics

Questions to drive discussion:

- What metrics has your team established that span beyond measuring level of effort or total output?
- How do the metrics relate to driving impact through analytic production or insights?
- What approaches has your team taken to capture this feedback in a semi-automated way and how effective has it been?

Closing the Loop: Feedback

- How? Periodic interview? Form?
- Timeliness, Actionability, Relevance, Completeness
- Capture and standardize qualitative feedback
- Celebrate anecdotal wins
- It's okay to be obnoxious about soliciting feedback



How did you
use this
report?

How could it
have better
fit your
workflow?

Intelligence Feedback Form

Use this form to elicit feedback from stakeholders about a specific intelligence publication.

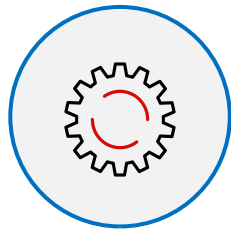
Report title:

Report number:

Stakeholder recipient(s):

How relevant was the content to your requirements?			
1 – Not relevant	2	3 – Highly relevant	
☐	☐	☐	
If not relevant, please tell us why (select all that apply)			
☐ Did not satisfy an existing <u>PIR</u>		☐ PIR is no longer <u>relevant</u>	
☐ Out of scope, too tactical		☐ Content was not <u>accurate</u>	
☐ Out of scope, too strategic		☐ Other: _____	
How timely was the content to your requirements?			
1 – Not timely	2	3 – Highly timely	
☐	☐	☐	
If not timely, please tell us why (select all that apply)			
☐ Content was <u>stale</u>		☐ Content was difficult to <u>consume</u>	
☐ Report was delivered <u>late</u>		☐ Other: _____	
☐ Report was on time, but action was already <u>taken</u>			

ENHANCE



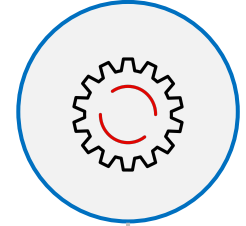
Key Outcomes:

Operational Continuity
& Preparedness

Embrace Best Practices, Best Fit, and Regular Review



ENHANCE



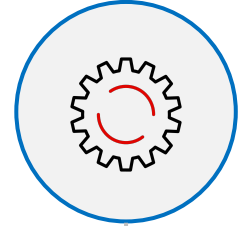
Key Outcomes:

Operational Continuity
& Preparedness

Create Cross-Training OTJ Opportunities

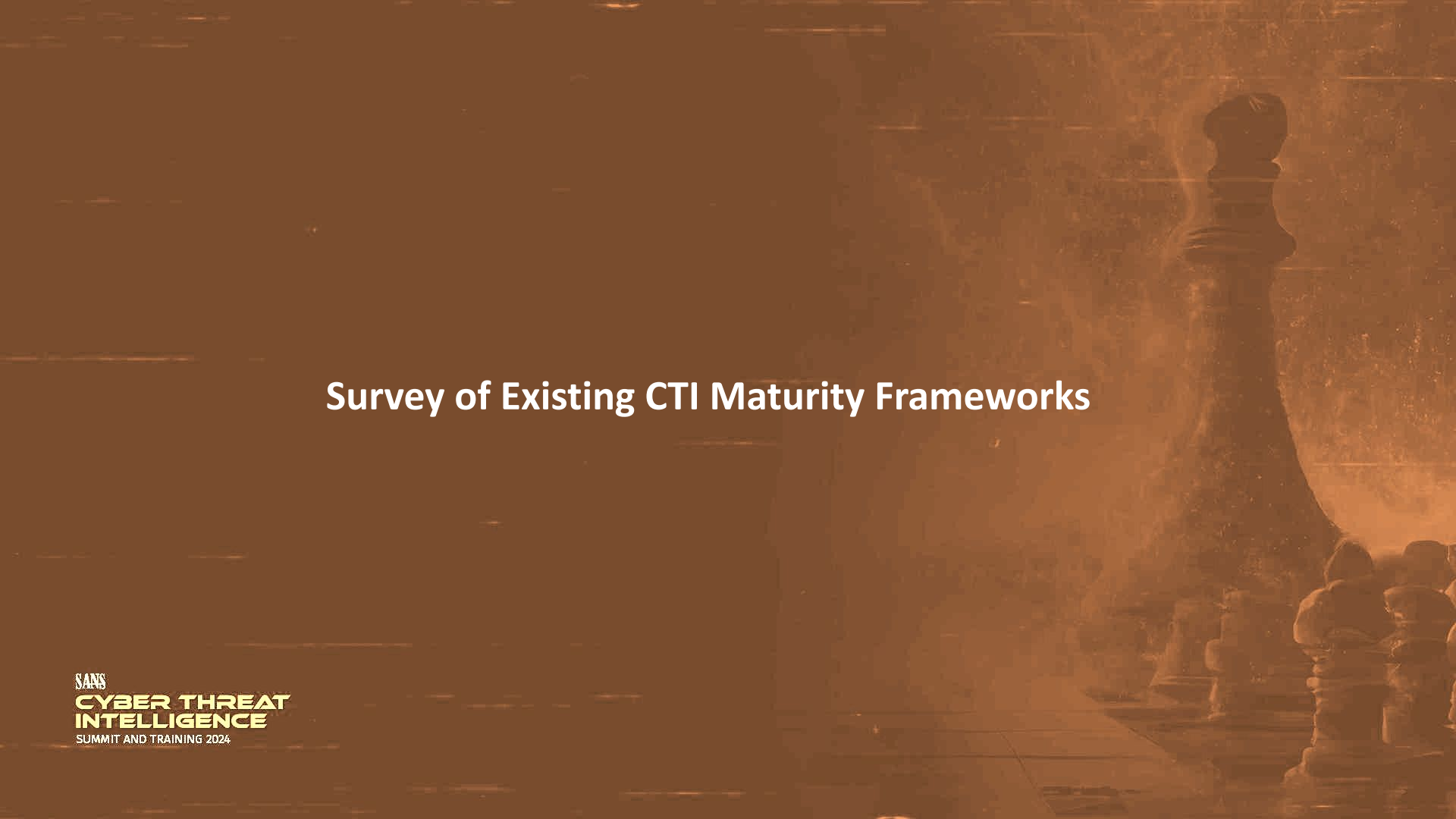
- Knowing your teams current skillset can help identify areas for improvement
- CTI leaders can use information from exercises like the skillset inventory to partner senior members of the team with more junior analysts to bolster skills
- Brown-bag style training sessions presented by and to members of the CTI team can help broaden skillsets and encourage collaboration
- Ultimate goal is no single points of failure; if X is out or leaves UC there is little to no disruption.
- Cross training across the different offerings the CTI team has can help ensure that products have a consistent voice and detail level of analysis

ENHANCE



Key Outcomes:

Operational Continuity
& Preparedness

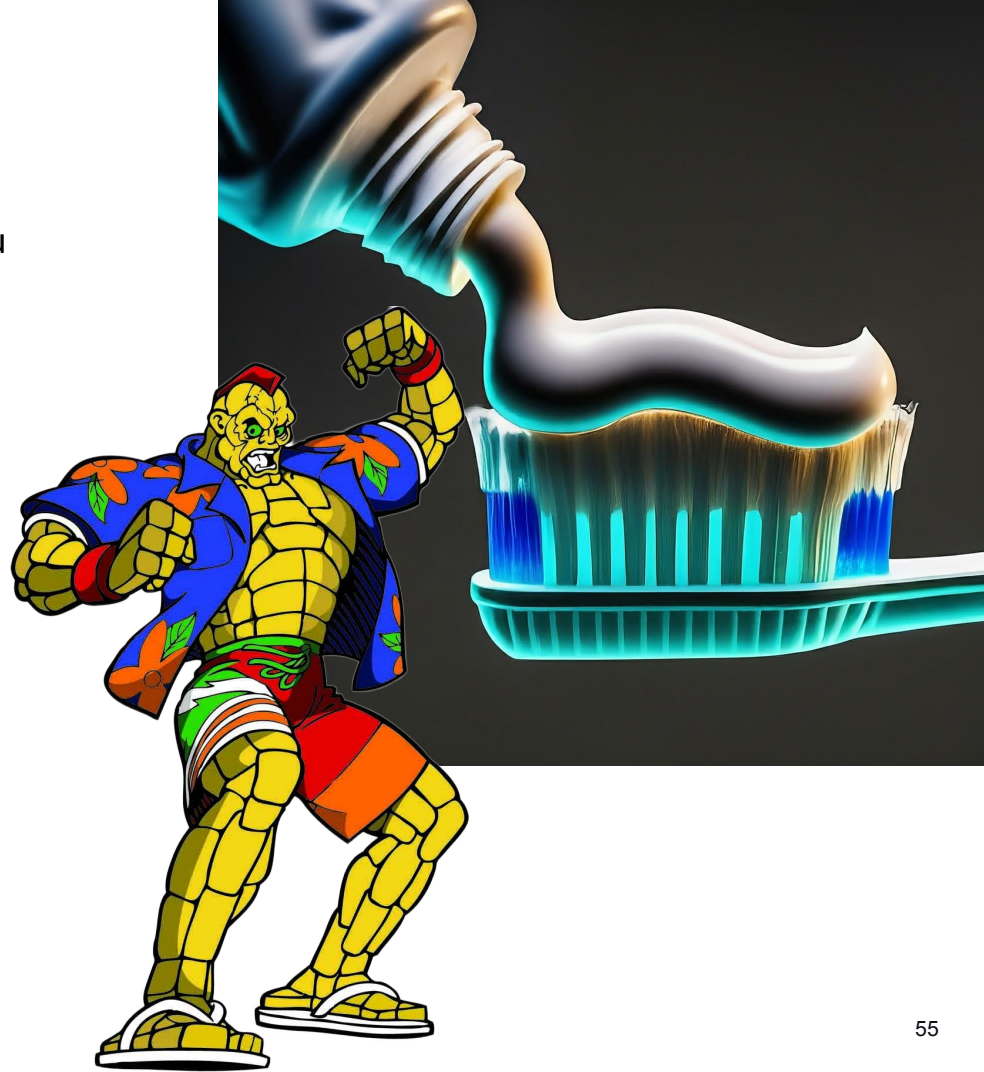


Survey of Existing CTI Maturity Frameworks

What's Out There Now?

Existing frameworks: If you are building as you fly, you do not have to also invent the airplane from scratch.

- CTI Maturity Frameworks
 - CTIM.eu
 - CREST
 - ENISA
 - EclecticIQ
- Cyber Defense Frameworks
 - Cybersecurity Capability Maturity Model (C2M2)
 - NIST Cybersecurity Framework



Compare and Contrast: It's Academic

Academic review of six available models in
“Evaluation of Cyber Threat Intelligence Maturity
Models: A Comparison Based on Maturity Model
Design Principles”, by H. D. Pambudhi and R. F. Aji

- How well does it fulfill the basic design of a maturity model?
- How well does it capture descriptive components of a program?
- How well does it convey prescriptive measures of a program?

Highest rated was CTIM.eu, but the variety is the point.

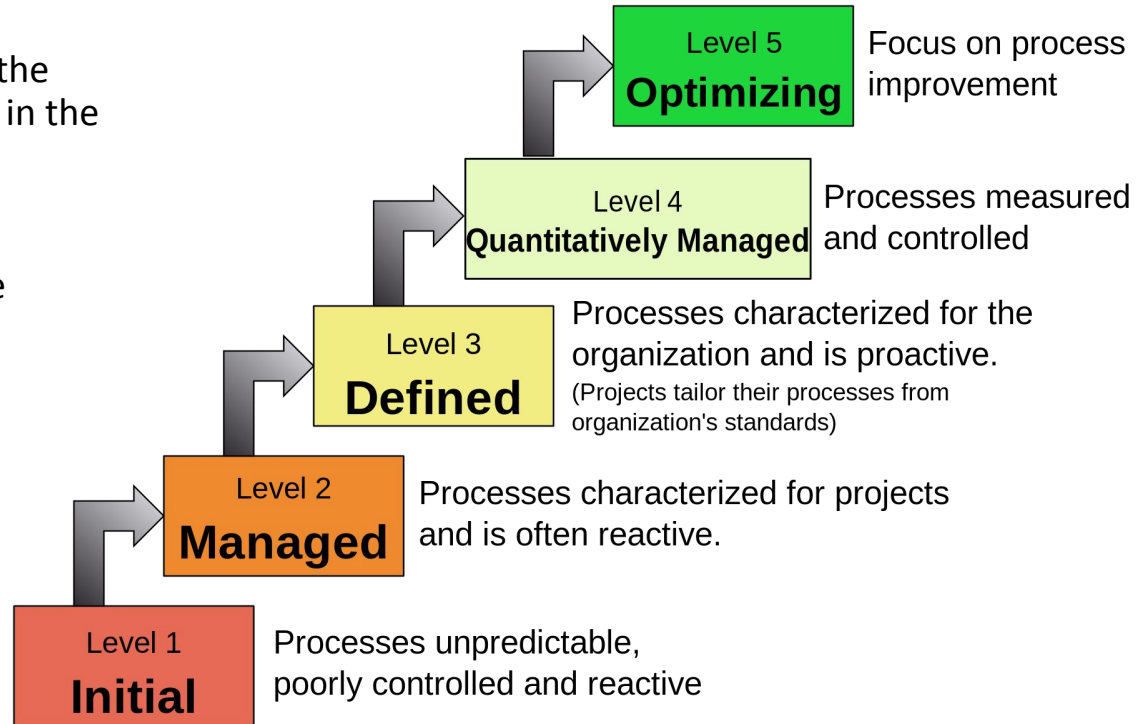


The Application of Capability Maturity Model Integration

Characteristics of the Maturity levels

Broad, customizable buckets

- Tie it internally to functions and the roadmap we discussed way back in the design phase
- Typically some sort of qualitative bucket or goal state
- Clearing given thresholds may be consensus-based



EclecticIQ

Mapping eight production processes across five levels of maturity

Production Focused,
Consumer Agnostic

Qualitative
descriptors/thresholds

Capabilities	Stage 1	Stage 2	Stage 3	Stage 4	Stage 5
Stakeholder Management	Little to no awareness of what threat intelligence is and what business capability is responsible for it	Threat intelligence sometimes makes it to stakeholders, but is rarely considered and acted upon.	Threat intelligence is regularly sent to stakeholders and consistently considered and acted upon.	Threat intelligence is consumed as a standard input and regularly used in decision making around cyber-related issues.	Threat intelligence is consumed as a standard input, with advice actively sought on significant decisions.
Requirements Management	No requirements, or requirements not based on stakeholder input	General understanding of stakeholder needs through informal or irregular touchpoints	Regular and established touchpoints to understand stakeholder needs	Regular and established touchpoints to understand stakeholder needs, with ad hoc feedback on received intelligence	Regular and established touchpoints to understand stakeholder needs, with regular, ongoing feedback on received intelligence
Awareness	No awareness of threats	Some awareness of commonly (and publicly) discussed threats	Some awareness of threats, including trends in threat actor capabilities and motivations	Deeper insight into trends affecting common threats, and a good understanding of actor capabilities, motivations, and persistence	Awareness of most relevant threats, including uncommon and targeted threats, and recognition of actor capabilities, motivations, and persistence
Source Management/collection	None or ad hoc	Irregular decision making on source acquisition; mostly open sources or sources of unknown reputation	Regular decision making on source acquisition and realignment; a wider range of mostly reputable sources	Established procedures to acquire, evaluate, and realignment sources; many reputable, well-known sources with a regular collection of unique analysis capabilities	Established procedures to acquire, evaluate, and realignment sources; a large set of reputable sources, including well-known and niche sources, offering a consistent supply of unique collection or analysis capabilities
Analysis and Production	No analysis or intelligence from sources is dissemination or integrated directly	Intelligence received is enriched and qualified using automatic or manual methods.	IOC Management: technical indicators and observable components are nurtured with quality control.	TTP Management: threshold criteria dictate when intelligence warrants ad hoc, case-based, and collaborative research to improve TTP-based understanding of specific threats.	Threat Management: threats are proactively and strategically managed from a central register; continuous research is performed proactively to understand known threats.
Sharing	No sharing	Sharing with individuals at similar organizations	Sharing through semi-regular meetings with individuals and semi-sensitive groups	Ad hoc sharing via institutional relationships or within sensitive, trusted groups	Regular sharing via institutional relationships or within sensitive, trusted groups
Dissemination	Intelligence is disseminated directly from sources	Disseminated intelligence has ample context and confidence statements to understand the relevance to the receiving stakeholder	Disseminated intelligence targets the specific stakeholder	Intelligence is created collaboratively with stakeholders to validate and test key hypotheses; conclusions are sent directly to the relevant stakeholders.	Stakeholders have complete control over the timing, delivery method, and subject matter of intelligence reports and receive targeted intelligence on relevant topics when necessary.
Integration	No integration of intelligence from sources into security controls and workflow systems	Irregular integration of Intelligence indicators into security controls and workflow controls	Regular integration of Intelligence indicators into security controls and workflow controls	Intelligence indicator integration into security and workflow controls with information about context, priority, and specific courses of action	Intelligence indicator integration into security and workflow controls with information about context, priority, and specific courses of action, as well as clear and easy-to-understand drill-down into analytics and intelligence of the surrounding context

Why another assessment framework?

We're delivering a **use case-driven approach** that ties **CTI practices to business realities** and **achievable impact**.

We want this to be approachable and accessible for an organization regardless of size, and provide clear next steps rather than a survey of all possibilities.



Mandiant's CTI Maturity Assessment

- In development since Nov 2023, should be live by end of Feb 2024
- 42 measures over 6 capability areas

Intelligence Capability Assessment (ICA)

Through a series of prompts, assessment takers will self-rate their program across a series of measures derived from what Mandiant considers best practice. For each measure you will be presented with, please select the option that best reflects the current state of your cyber threat intelligence (CTI) program relative to its current expectations and business needs:

- **Full:** This option indicates that your program fully meets all requirements outlined in the measure.
- **Partial:** This option indicates that your program meets some the requirements outlined in the measure.
- **None:** This option indicates that your program does not currently meet any of the requirements outlined in the measure.
- **Non-Applicable (N/A):** This option indicates that the measure is not relevant to your specific CTI program.

ICA Overview (0/1)

Organizational Role of CTI (0/5)

Intelligence Services and CTI Use Cases (0/7)

Analyst Capability and Expertise (0/5)

Intelligence Process Lifecycle (0/7)

Analytic Practices and Products (0/12)

Technology Integration (0/6)

Organizational Role of CTI

Established and
Recognized

QUESTION 1 OF 5

≡ Notes

Is the CTI function recognized by all areas within cyber security and risk management as a supporting service?

- ☐ Full
- ☐ Partial
- ☐ None
- ☐ N/A

Established and
Recognized

QUESTION 2 OF 5

≡ Notes

Is the CTI function a recognized, formalized part of the organization with an explicit call out on the organizational chart that operates in accordance with authorities granted in its program charter?

- ☐ Full
- ☐ Partial
- ☐ None
- ☐ N/A



Mandiant's CTI Maturity Assessment

- Recommendations provided for each pillar
- Scores and recommendations can be emailed, which display in-line and includes a PDF export

Intelligence Capability Assessment (ICA): Discovery Results

[1 Actions](#)

100

Overall Score

OPTIMIZED

Assessment completed on: Jan 26, 2024 9:50 AM

Domain name: **naver.com**

Maturity scores by pillar (score out of 100) and rating, on a scale of: reactive (>0 and <= 25), proactive (>25 and <= 50), adaptive (>50 and <= 75), optimized (>75 and <= 100).

100

ICA Overview

OPTIMIZED

100

Organizational Role of CTI

OPTIMIZED

100

Intelligence Services and CTI Use Cases

OPTIMIZED

100

Analyst Capability and Expertise

OPTIMIZED

100

Intelligence Process Lifecycle

OPTIMIZED

100

Analytic Practices and Products

OPTIMIZED

100

Technology Integration

OPTIMIZED

Recommendations

[<](#) [ICA Overview](#) [Organizational Role of CTI](#) [Intelligence Services and CTI Use Cases](#) [Analyst Capability and Expertise](#) [Intelligence Process Lifecycle](#) [Analyst](#) [>](#)

Strategic Support

OPTIMIZED

The CTI function, by design, serves a key role within the organization's cyber security mission feeding into several of those categories in the NIST CSF, providing situational awareness on threats, crafting threat impact assessments, and advising on risk reduction efforts. As a service function, CTI provides stakeholders with timely and relevant insights about the cyber threat landscape, cyber threat actors, their capabilities, operations, and motivations to inform risk exposure, planning, and cyber defense actions. Analytic support and its corresponding outcomes can take many different forms and often CTI employs a niche, yet logical structure to break out corresponding support types across three primary categories: strategic, operational, and tactical.

Strategic stakeholders often seek high level information on intrusion activities that may introduce additional risk to the organization or how emergent technologies can be integrated to further drive down risk. Strategic analytic insights should aim to guide investments, priorities, and new initiatives. Analytic support to strategic stakeholders across cyber security leadership, risk management, and security awareness functions could include examining trends in intrusion activities, shifts in the cyber threat landscape, or advances in cyber security products or processes.

Resources

-  Better Together: The Benefits of Integrating Cyber Threat Intelligence WHITEPAPER 
-  Uncover Operational Technology Threats with Data Collection WHITEPAPER 
-  Proactive Preparation and Hardening to Protect Against 

Action Plan

(Click on the "Star" to add recommendations to plan)

Not favorited any resources or products.

 [Build Plan](#)

Summarize Recommendations (AI)

 [Summarize](#)



[Debo's Section]

CTI
CMM

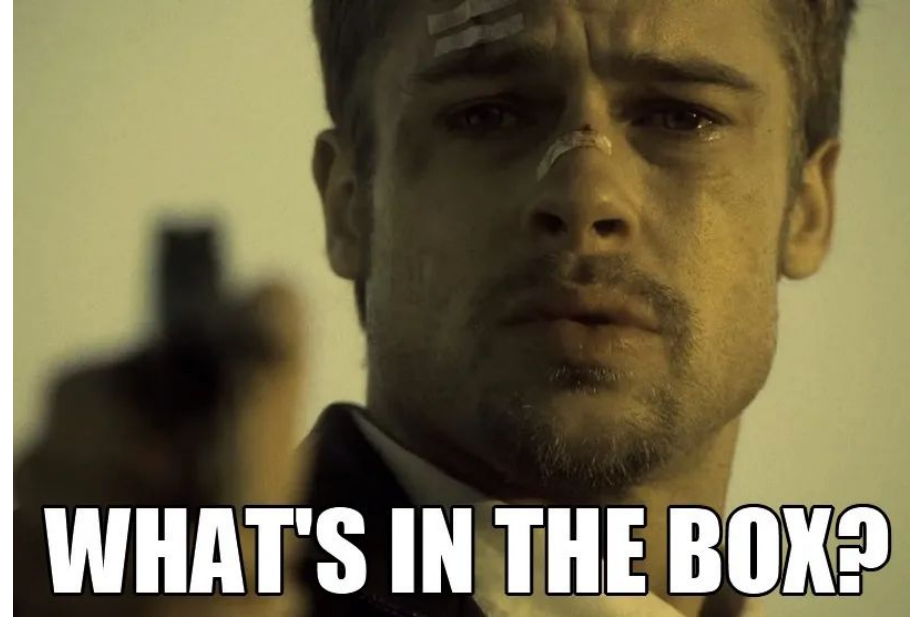
Exclusive
Sneak
Peek!

CYBER THREAT INTELLIGENCE
CAPABILITY MATURITY MODEL

Industry Inspired. Industry Led.

CTI-CMM Sneak Peek

- Why another maturity model?
- Who is this intended for?
- How will it be used?
- How is it being developed?
- How is it structured?
- What's next?



Why does this model exist?

Takes a **use case driven approach** to **establishing CTI maturity**

Focuses on **building CTI capabilities where needed:**

- Stakeholders & Use Cases
- Workforce development
- Program management

Ties CTI Practices to Business Outcomes



Who is this model for?



Leadership

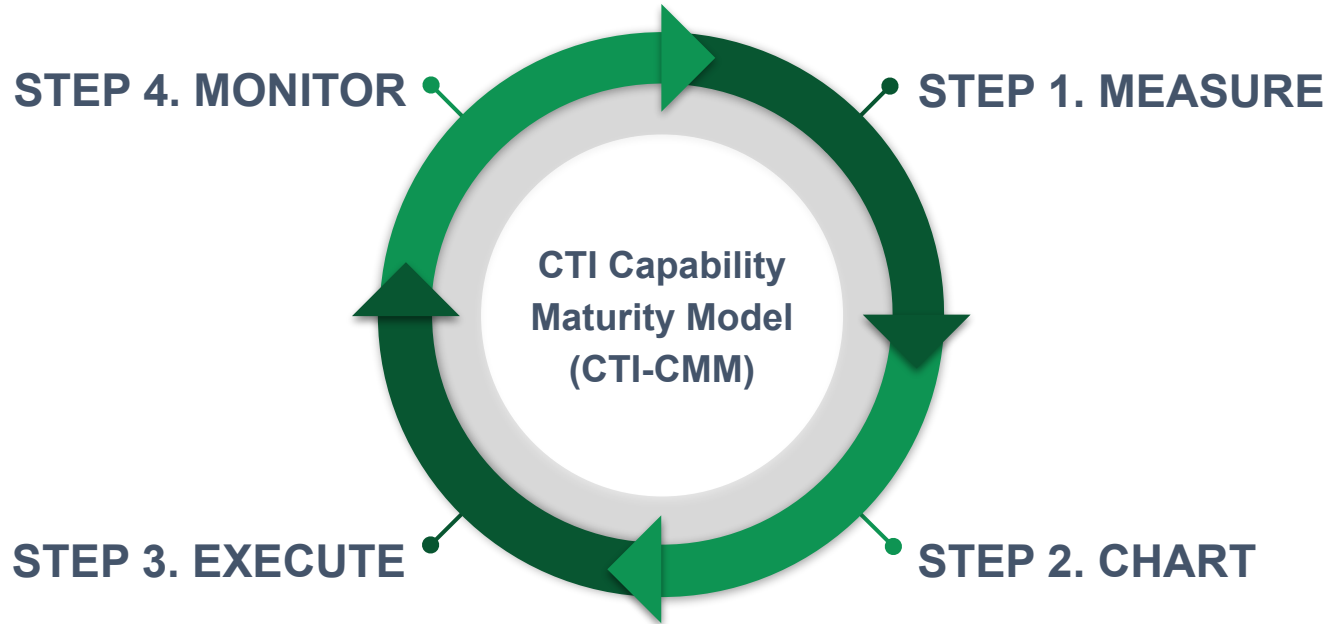
CTI Directors, Team Leaders
Cybersecurity Executives, Senior Staff



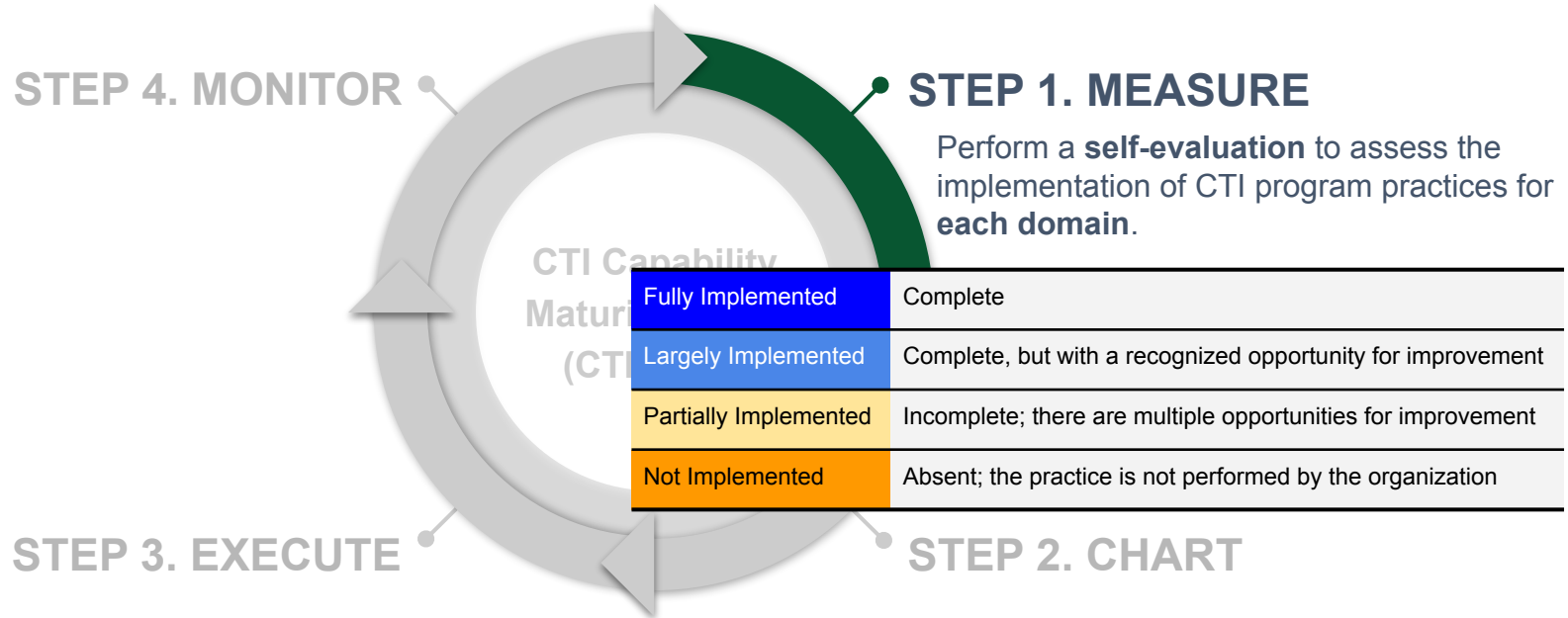
Practitioners

CTI Analysts, Researchers, Engineers
Cybersecurity Domain Stakeholders
(SOC analysts, incident responders,
etc.)

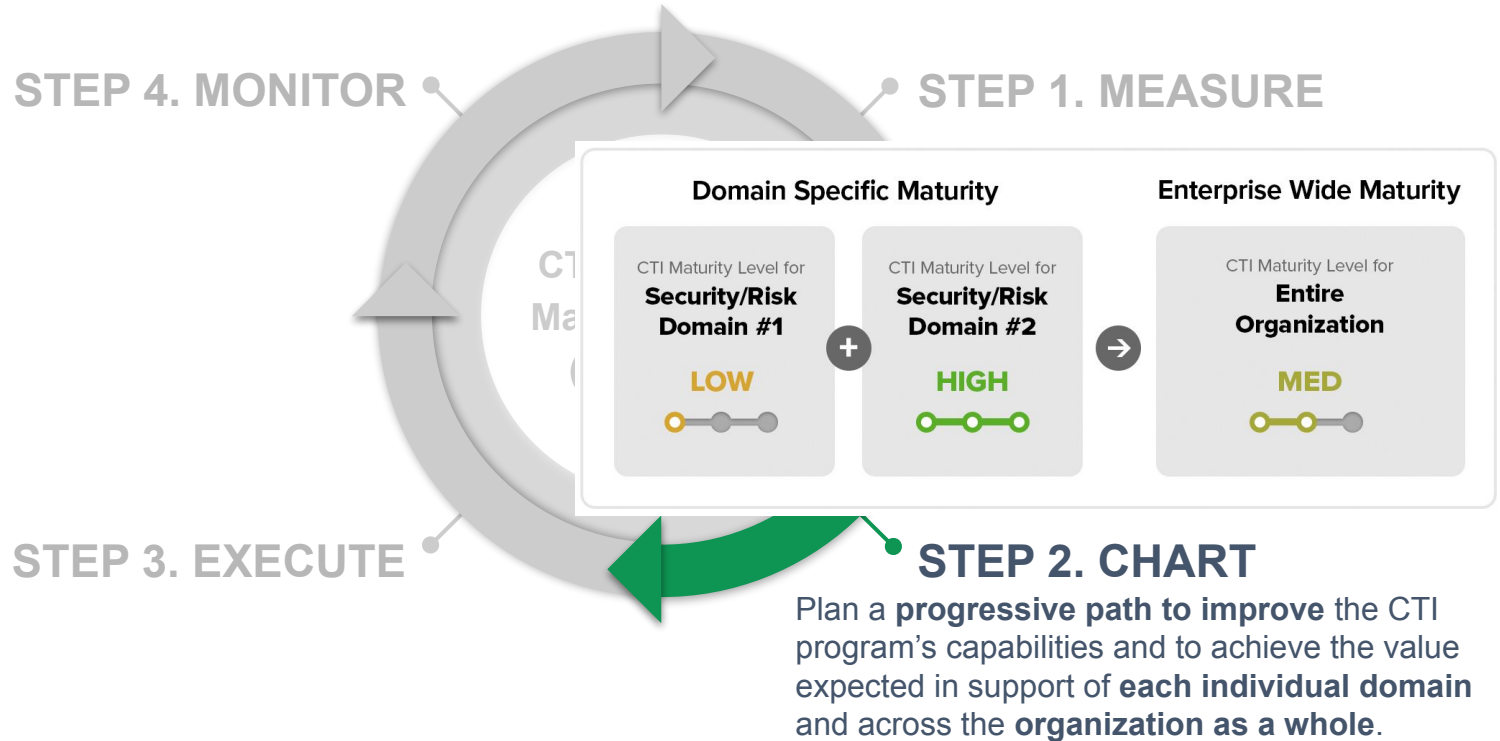
How will this model be used?



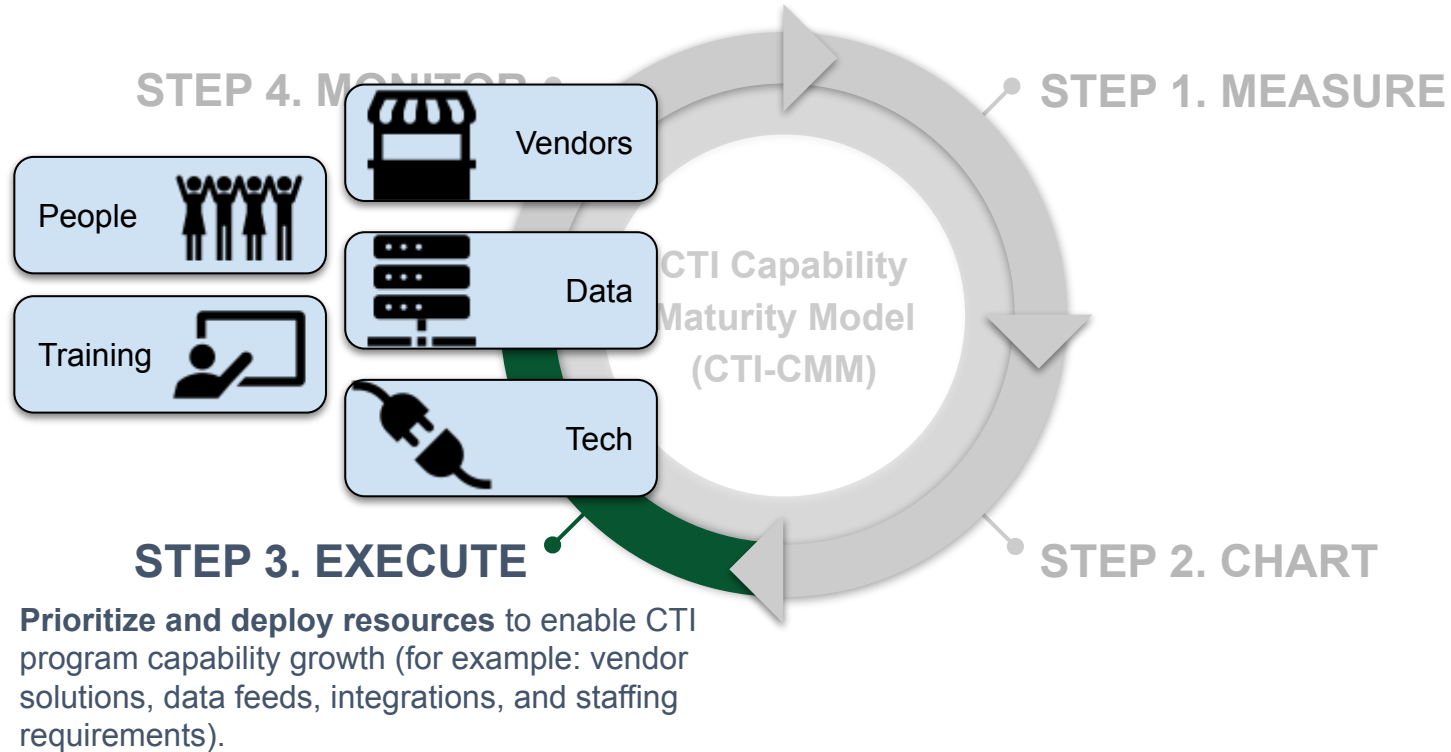
How will this model be used?



How will this model be used?



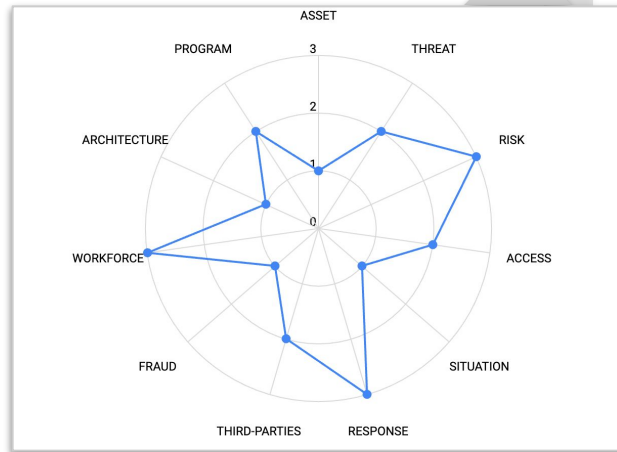
How will this model be used?



How will this model be used?

STEP 4. MONITOR

Continuously monitor and compare the CTI program's maturity level proportionate to the capabilities of each individual domain it supports.



CTI Capability
Maturity Model
(CTI-CMM)

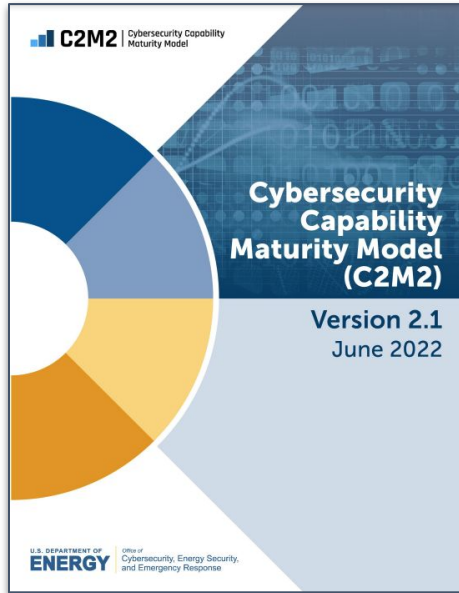
STEP 1. MEASURE

STEP 2. CHART

How is it being developed?

Industry Inspired

Industry Led



How is it being developed?

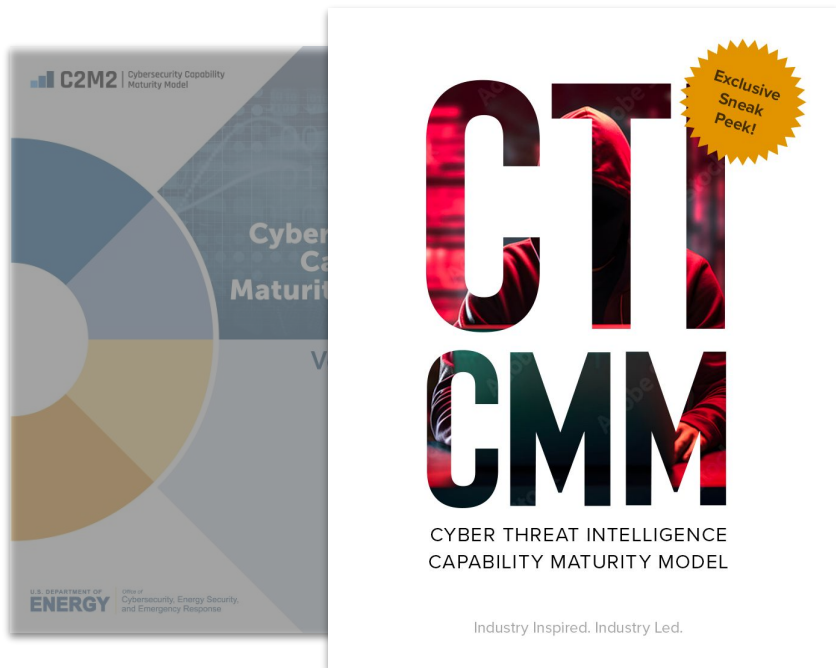
Industry Inspired

Industry Led



How is it being developed?

Industry Inspired



Industry Led

Program Lead

Michael DeBolt, Intel 471

Contributors

Nicole Beckwith, Kroger
John Fokker, Trellix
Clay Hamilton, Autodesk
Scott Small, Tidal Cyber
Colin Connor, IBM
Kobe Schwartz, Signify
Ian Thompson, BP
Jurgen Visser, Gojek

Contributors from a large
US-based multinational
financial institution

Advisors & Reviewers

Michael Haas, Kroger
Freddy Dezeure, Advisor
Joe Opacki, Verizon
Rick Holland, ReliaQuest

How is it structured?

Domains

CTI Use Cases

CTI Practices

Maturity Levels

CYBER THREAT INTELLIGENCE
CAPABILITY MATURITY MODEL

How is it structured?

Domains

The stakeholder domain, typically derived from the C2M2

CTI Use Cases

CTI Practices

Maturity Levels

11 Cybersecurity Domains



How is it structured?

Domains

The stakeholder domain, typically derived from the C2M2

CTI Use Cases

CTI Practices

Maturity Levels



How is it structured?

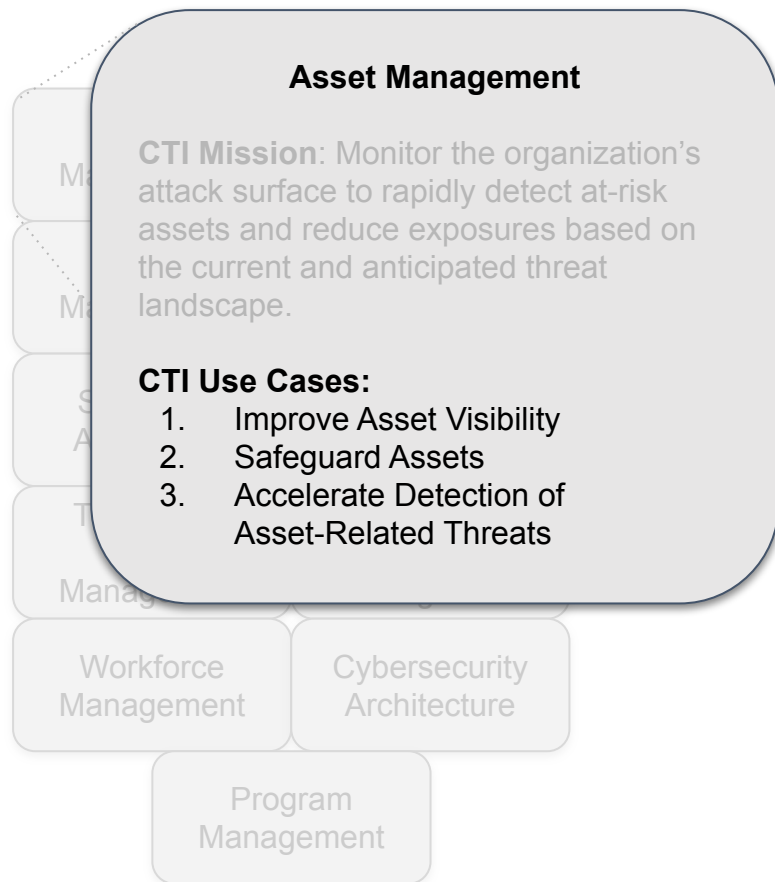
Domains

CTI Use Cases

The objectives needed to complete the CTI mission.

CTI Practices

Maturity Levels



How is it structured?

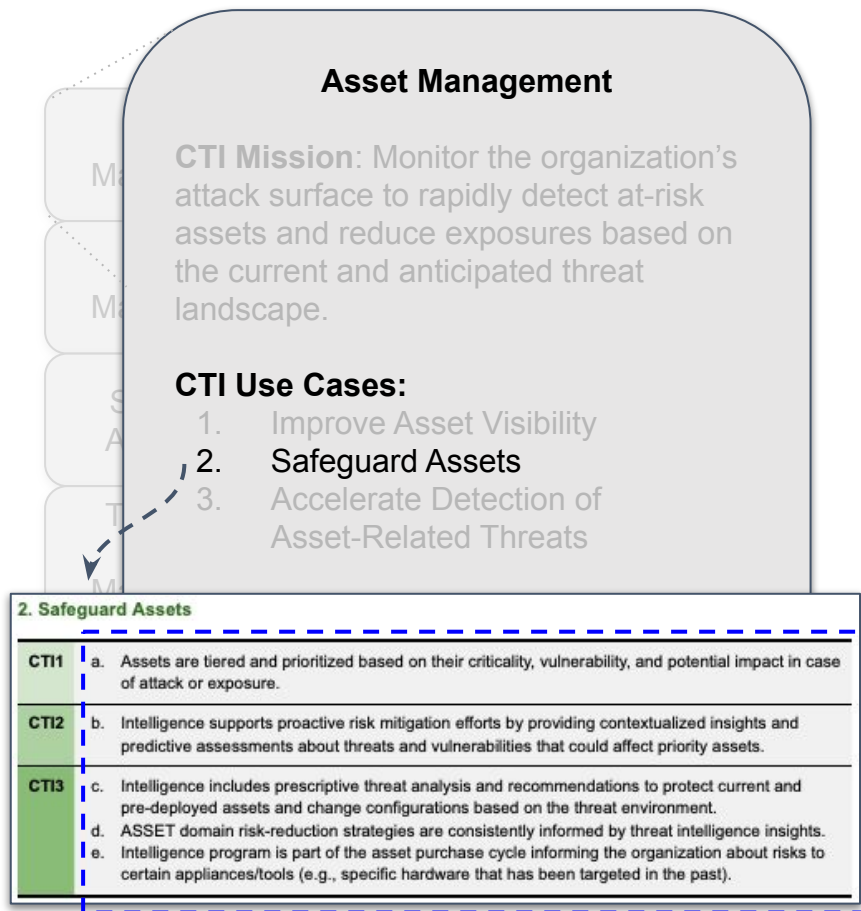
Domains

CTI Use Cases

CTI Practices

Each Use Case consists of specific practices across maturity levels

Maturity Levels



How is it structured?

Domains

CTI Use Cases

CTI Practices

Maturity Levels

Individual practices are listed within each level based on their maturity level characteristics.

CAPABILITY MATURITY MODEL

Asset Management

CTI Mission: Monitor the organization's attack surface to rapidly detect at-risk assets and reduce exposures based on the current and anticipated threat landscape.

CTI Use Cases:

1. Improve Asset Visibility
2. Safeguard Assets
3. Accelerate Detection of Asset-Related Threats

2. Safeguard Assets

- | | |
|-------------|--|
| CTI1 | a. Assets are tiered and prioritized based on their criticality, vulnerability, and potential impact in case of attack or exposure. |
| CTI2 | b. Intelligence supports proactive risk mitigation efforts by providing contextualized insights and predictive assessments about threats and vulnerabilities that could affect priority assets. |
| CTI3 | c. Intelligence includes prescriptive threat analysis and recommendations to protect current and pre-deployed assets and change configurations based on the threat environment.
d. ASSET domain risk-reduction strategies are consistently informed by threat intelligence insights.
e. Intelligence program is part of the asset purchase cycle informing the organization about risks to certain appliances/tools (e.g., specific hardware that has been targeted in the past!). |

How is it structured?

Domains

CTI Use Cases

CTI Practices

Maturity Levels

Individual practices are listed within each level based on their maturity level characteristics.

Level	Characteristics
CTI0 - Pre-Foundational	No practices are performed at this level.
CTI1 - Foundational	Basic practices are performed but are mostly ad-hoc or unplanned, with a focus on reactive intelligence that delivers short-term results.
CTI2 - Advanced	- Advanced practices are performed at a higher level than CTI1. - Practices are mostly planned and routine, with a focus on proactive and predictive intelligence that delivers short- and intermediate-term results.
CTI3 - Leading	- Leading practices are performed at a higher level than CTI2. - Practices include a focus on prescriptive intelligence and recommendations that deliver long-term strategic results. - Practices are measurable and aligned to business outcomes.

CTI-CMM Domain & Purpose
The stakeholder domain, typically derived from the C2M2

CTI Mission
The stated goal of the CTI program to support the domain

CTI Use Cases
The objectives needed to complete the CTI mission

CTI Data Sources
The data needed to achieve the CTI use cases

CTI Use Cases and Practices
Each Use Case consists of specific practices across maturity levels

Individual practices are referenced as:

DOMAIN-Objective.Practice

For Example:

ASSET-1.b

4.1. Asset, Change, and Configuration Management (ASSET)

Domain Purpose: Manage the organization's IT and OT assets, including both hardware and software, and information assets commensurate with the risk to critical infrastructure and organizational objectives.

CTI Mission: Monitor the organization's attack surface to rapidly detect at-risk assets and reduce exposures based on the current and anticipated threat landscape.

CTI Use Cases

1. Improve Asset Visibility
2. Reduce Attack Surface Exposure
3. Accelerate Detection Time

CTI Data Sources

- Attack Surface Intelligence
- Vulnerability Intelligence

CTI Use Cases and Practices

1. Improve Asset Visibility

CTI1	a. Alerts about threats against inventoried assets are delivered at least in an ad-hoc manner.
CTI2	b. Intelligence is routinely delivered about threats against previously undiscovered or unmanaged assets. c. Intelligence consistently includes detailed context and threat assessments to improve asset discovery practices and predict future threat scenarios based on the threat environment.
CTI3	d. Intelligence regularly includes prescriptive threat analysis and recommendations to support the discovery of current assets and configurations. e. ASSET domain inventory and change management decisions are regularly informed by threat intelligence outputs.

Example: Threat-Informed Asset Management

Acme Inc.'s highly capable CTI program synchronizes its efforts with the priorities of the organization's asset management objectives. CTI analysts use attack surface and vulnerability intelligence to provide just-in-time alerting about exposed assets, insights into threats posed against the organization's attack surface, and recommendations that assist risk reduction activities.

The CTI program operates with a heightened focus on rapidly identifying previously unknown exposures, and proactively informing asset management stakeholders of threat intelligence that shapes asset deployment and configuration strategies.

Welp, what's next?

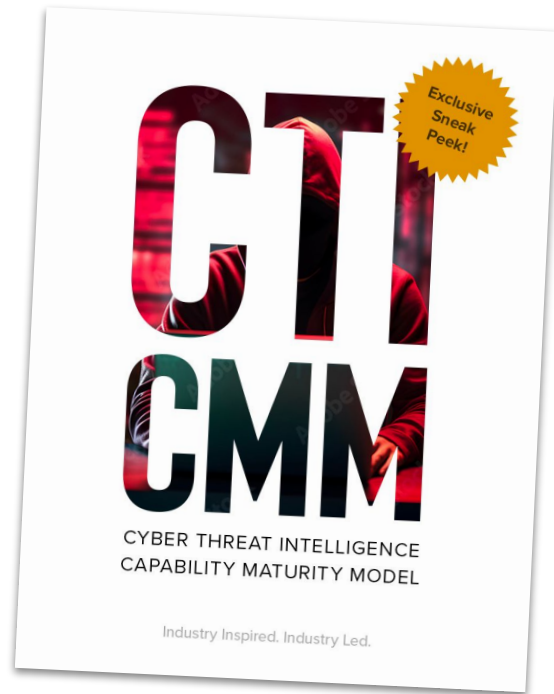
Our Goal: **CTI-CMM v1 Publication: Mid-2024**

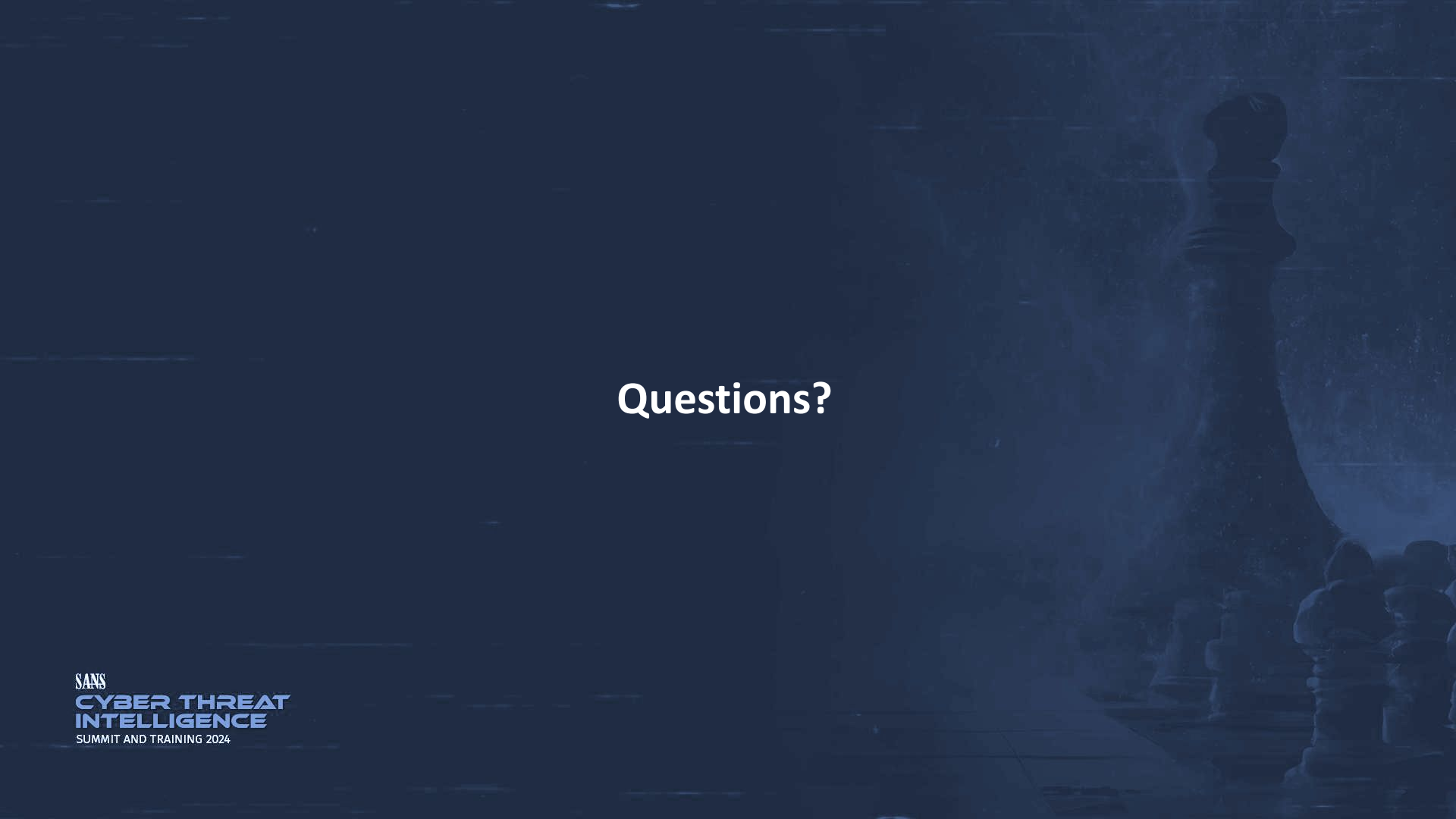


Until then,

- Join the waitlist and ... wait.
- Grab a “sneak peek” handout
- Spread the word!
- Lunch and Learn Webinar(s)
- Interested in contributing?? HMU

<https://intel471.com/cti-cmm-handbook-waitlist>





Questions?

GET IN TOUCH



JOHN DOYLE

@_John_Doyle

in/john-doyle-a02bab10/



STEVE SAVOLDELLI

@InfoSecSav

in/steven-savoldelli-14a84812/



MICHAEL DEBOLT

@michael_deebo

in/mdebolt/